CertGraph: Cryptographic Invariant Provenance and Multiplicative Bilinear Gating for Active Directory Certificate Services Escalation Interdiction

Md. Hasan Shahriar, Taufiq Biswas, and Md. Ramim Hossain

***Abstract*—An ADCS certificate can remain usable after the template that enabled its issuance has been restored. Investigating that sequence requires evidence from directory changes, certificate issuance and domain authentication, whose records do not always expose matching identifiers. CertGraph combines graph analysis, certificate-specific provenance and remediation within an assigned disruption budget. Its evidence contract scopes certificate identity to the issuer, retains compatible candidates when fields are missing, and revises attribution when later records conflict. We evaluate the contract using synthetic histories and controlled Windows experiments. In a frozen 5,400-history study, the randomized subset retains 99.06% of true observed links as candidates and resolves 55.82% definitively. Four intervention matrices and a separate concurrent forest workload provide 72 certificate cases: 66 successful exact-certificate authentications, including 13 administrative uses, and six certificate-bound rejections. Current-patch controls distinguish rejection of UPN-only requests from administrative use of SID-URL certificates after template restoration. A guarded SQLite implementation agrees with the identity reference at all 5,423 evaluated prefixes. Separate graph-learning experiments reproduce 10,800 held-out predictions but find no classification advantage for bilinear gating over matched additive attention. The remediation evaluation checks 120 graph/budget instances and exposes heuristic optimality gaps. These results support certificate-specific investigation under explicit evidence assumptions; they do not establish general deployment effectiveness.**

***Index Terms*—Active Directory security, certificate services, provenance analysis, incomplete evidence, graph learning, network interdiction.**

I. Introduction

Active Directory Certificate Services (ADCS) issues certificates that can be used for domain authentication through PKINIT [1]. Different services record issuance and subsequent use. When a certificate template is changed, used and restored between scans, its current configuration no longer describes the conditions under which an earlier certificate was issued. Investigators must therefore connect directory changes, CA records and KDC authentication outcomes.

SpecterOps documented certificate-service escalation techniques [2]. Certificate mapping and the installed Windows updates also affect whether a certificate is accepted for an administrative identity [3]. We ask what certificate-specific attribution is justified when identifiers or timing evidence are incomplete, late or contradictory.

The authors are with the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh. Corresponding author: Md. Hasan Shahriar (e-mail: hasanshahriar32@gmail.com).

A. Certificate Issuance and the Evidence Gap

In an ADCS deployment, certificate issuance is governed by Active Directory objects known as *Certificate Templates* (stored in the LDAP configuration naming context). When an enterprise template exposes an insecure combination of attributes—such as the `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` bitflag alongside an Extended Key Usage (EKU) permitting Client Authentication (`1.3.6.1.5.5.7.3.2`) or Smart Card Logon (`1.3.6.1.5.2.3.4`), without requiring CA administrator approval—any domain principal granted enrollment permissions can request an X.509 certificate specifying an arbitrary Subject Alternative Name (SAN). The attacker can supply the user principal name (UPN) of a Domain Administrator (e.g., `Administrator@domain.local`), obtain a cryptographically valid certificate signed by the enterprise root CA, and submit that certificate to the Kerberos Key Distribution Center (KDC) via PKINIT to request a Ticket Granting Ticket (TGT), when the KDC accepts the resulting identity mapping. Certificate-binding policy and patch level can prevent this outcome [3].

Configuration assessment and incident reconstruction answer different questions. Certipy reports template and CA risks [4]; a positive finding does not by itself show that a certificate was used with elevated privileges. Whole-network provenance systems connect activity across hosts [5, 6], but a certificate-level explanation still needs an issuer-scoped link between issuance and use.

This study examines three issues. First, a graph classifier can learn template attributes that correlate with generated labels while missing the access-control path. Such shortcut behavior is a known learning problem [7]; our experiments test it under a stated ADCS permission abstraction. Second, restored configuration attributes cannot identify every intervening issuance. Third, the captured CA and KDC records expose different certificate fields. Existing SAN-based CA/KDC queries provide useful operational correlation [8, 9]. We examine what can still be concluded when the required fields are absent or disagree.

B. Our Contributions

CertGraph combines graph analysis, certificate-specific evidence reconstruction and budget-constrained remediation. The contributions and their evaluation boundaries are as follows:

- **Certificate-specific attribution.** We specify how issuer-scoped issuance records, certificate identifiers and authentication outcomes support possible, definite, conflicting or

withdrawn links. Synthetic histories measure the trade-off between retaining candidates and making definite attributions. Controlled Windows matrices and a concurrent transfer workload supply 72 outcome-checked certificate cases. An equal-input SQL comparison tests whether the contract can be expressed relationally.

- **Matched analysis of graph learning.** We give a conditional feature-sensitivity result and distinguish the historical feature-channel implementation from a literal bilinear model. The latter reproduces 10,800 held-out predictions on family-disjoint inputs. Its classifications match additive attention, and both models miss the tested long-path positives. The result identifies a verification requirement rather than demonstrating a general advantage for gating.
- **Measured remediation trade-offs.** We formulate interdiction with assigned disruption costs and immutable permissions. A metadata-preserving rerun checks 120 graph/budget instances; exhaustive small cases expose gaps from the optimum. A separate path-preserving projection compares the same reachability task. These experiments evaluate the specified instances and costs, not production disruption or a guaranteed optimal policy.

C. Paper Organization

The remainder of this manuscript is organized as follows: Section II formalizes the heterogeneous identity multigraph schema and demonstrates the static snapshot blind spot and ASN.1 SAN concealment on live systems. Section III details the CertGraph GNN architecture and the gating formulation and its implementation boundary. Section IV develops the CIPG provenance engine and Invariant V automaton. Section V details the game-theoretic Stackelberg defense and NP-hardness proof. Section VI presents empirical results across synthetic and live GOAD cyber-range testbeds. Section VII reviews related work. Section VIII discusses deployment costs and validity, and Section IX concludes the paper.

II. ADCS Threat Model and Systematic Blind Spots

In this section, we formalize the heterogeneous identity multigraph of Active Directory Certificate Services and expose two fundamental blind spots in current defensive audit practices: the static snapshot blind spot under rollback attacks, and the PKCS#10 ASN.1 schema discontinuity between CA and KDC telemetry.

A. Heterogeneous Access Control Multigraph Formalization

We model an enterprise Active Directory forest and its integrated Public Key Infrastructure as a directed heterogeneous multigraph (Figure 1).

Definition II.1 (Identity Multigraph Schema)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E}, \phi, \psi)$ be a directed heterogeneous multigraph, where:

- $\mathcal{V}$ is the finite set of identity and PKI vertices, and $\phi : \mathcal{V} \to \mathcal{T}_V$ is a node-type assignment function mapping vertices to the entity set:

$$\mathcal{T}_V = \{\text{User}, \text{Group}, \text{Computer}, \text{CertificateTemplate}, \text{EnterpriseCA}, \text{Domain}\} \tag{1}$$

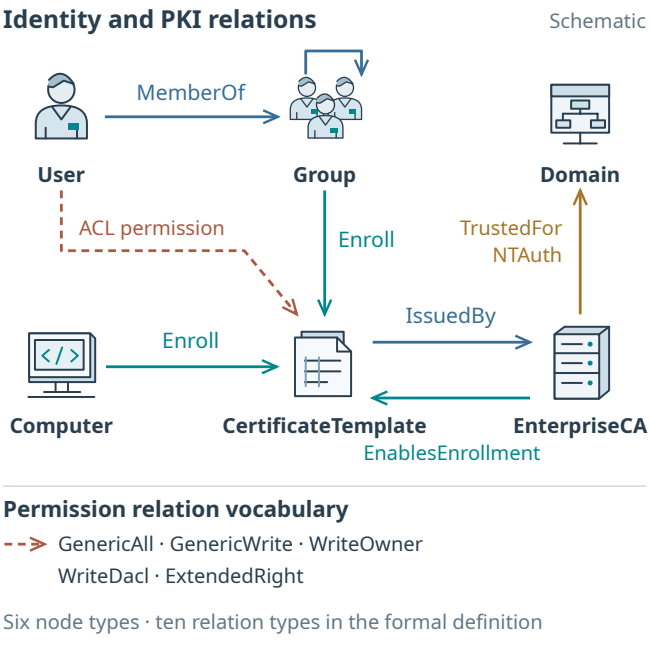


Fig. 1. Illustrative identity and PKI topology for the formal multigraph. Membership, enrollment, issuance and trust edges connect the six node types; the dashed ACL edge represents the permission vocabulary listed below the drawing. The topology illustrates the definition rather than an additional evaluated graph instance.

- $\mathcal{E}$ is the finite set of directed edges, and $\psi : \mathcal{E} \to \mathcal{T}_E$ maps edges to relationship types:

$$\mathcal{T}_E = \{\text{MemberOf}, \text{GenericAll}, \text{GenericWrite}, \text{WriteOwner}, \text{WriteDacl}, \text{Enroll}, \text{ExtendedRight}, \text{EnablesEnrollment}, \text{IssuedBy}, \text{TrustedForNTAuth}\} \tag{2}$$

- Each node $v \in \mathcal{V}$ is associated with a raw feature vector $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$. For certificate templates $t \in \mathcal{V}_{\text{Template}}$, $\mathbf{x}_t \in \{0,1\}^{10}$ encodes security configuration flags, including whether the template permits enrollee-supplied SANs (`CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`), requires manager approval (`CT_FLAG_PEND_ALL_REQUESTS`), or specifies Client Authentication EKUs (`1.3.6.1.5.5.7.3.2`).

An attack path p from an initial compromised user foothold $u_{\text{attacker}} \in \mathcal{V}_{\text{User}}$ to a high-value domain target $v_{\text{target}} \in \mathcal{V}_{\text{Domain}}$ is a sequence of alternating vertices and edges:

$$p = (v_0, e_1, v_1, e_2, \ldots, e_k, v_k), \quad v_0 = u_{\text{attacker}}, \quad v_k = v_{\text{target}} \tag{3}$$

In an ADCS privilege escalation, the path traverses intermediate membership and ACL delegation edges to a certificate template t, leverages an enterprise CA c to issue an administrative credential, and culminates in a domain-level credential takeover.

ADCS ESC1–ESC15 Taxonomy Scoping Rationale: Selected ESC categories illustrate different evidence requirements [2, 4]. This orientation is not a claim of evaluated ESC1–ESC15 coverage. We distinguish two operating regimes:

1) **Template-Centric Topological Vectors (Static Graph Evaluation):** Escalation archetypes ESC1 (enrollee sup-

plies SAN), ESC2 (any-purpose EKU), ESC3 (certificate request agent), ESC4 (template DACL overwrite), ESC9 (certificate templates omitting the security extension), and ESC13 (issuance policy OID linkage to administrative groups) are governed by directory access control lists (ACLs), group nesting DAGs, and persistent LDAP configuration flags. These vectors motivate graph modeling; the matched learning experiment evaluates only its stated resolved-permission ESC1 abstraction, not every listed ESC category.

2) **Runtime Protocol and Environmental Vectors (Dynamic Invariant Tracking):** In contrast, ESC6 (`EDITF_ATTRIBUTESUBJECTALTNAME2` CA registry flag), ESC7 (CA administrator compromise), ESC8 (HTTP certificate web enrollment NTLM relay), raw PKCS#10 ASN.1 SAN concealment, and temporal mutation rollbacks (ephemeral ESC4/ESC9 modifications) manifest as server-level registry states, network-layer NTLM reflections, or transient directory modifications that vanish between audit snapshots. Protocol activity and server-side settings need not be visible in a scheduled LDAP projection. Runtime and CA evidence therefore complement directory snapshots; this distinction does not imply that every listed vector leaves no persistent artifact.

B. Template Rollback and Snapshot Evidence

Existing enterprise defense workflows rely on periodic directory extraction tools (e.g., BloodHound, SharpHound, Certipy) that execute every 6 to 24 hours. Under temporal mutation-and-rollback attacks (such as ESC4 and ESC9), an attacker exploits transient write permissions to mutate a template, obtain a rogue certificate, and immediately roll back the attributes to their original configuration.

Definition II.2 (Static Snapshot Invariance under Rollback)**.** Let $t_0 < t_1 < t_2 < t_3$ denote the sequence of discrete timestamps in an attack execution lifecycle:

- t_0: Pristine baseline state of directory $\mathcal{G}_{t_0}$.
- t_1: The attacker executes an LDAP modification adding `Enroll` permissions or setting `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` on template t, yielding state $\mathcal{G}_{t_1}$.
- t_2: The attacker submits a certificate request and receives an issued certificate $\text{Cert}_{\text{admin}}$ valid for 1 year.
- t_3: The attacker rolls back the template modifications, restoring the directory attributes to their baseline state, yielding $\mathcal{G}_{t_3}$.

Snapshot Indistinguishability and Evidence Scope: For a projection restricted to configuration attributes restored by rollback, let h_0 and h_1 denote the digests before and during the mutation. The relevant equality is:

$$\text{SHA-256}(\mathcal{G}_{t_0}) = h_0 \tag{4}$$

$$\text{SHA-256}(\mathcal{G}_{t_1}) = h_1 \tag{5}$$

$$\text{SHA-256}(\mathcal{G}_{t_3}) = h_0 \tag{6}$$

This is a conditional indistinguishability argument for that projection, not evidence that the entire AD database is bit-identical. The earlier draft's literal digests cannot substitute for retained canonical input bytes. Let $\text{Obs}_{\text{static}}$ be this restored-attribute projection. With no other historical evidence, its observations are identical:

$$\text{Obs}_{\text{static}}(\mathcal{G}_{t_0}) = \text{Obs}_{\text{static}}(\mathcal{G}_{t_3}) \tag{7}$$

This does not assign a measured recall to every snapshot detector. The issued certificate can remain usable after rollback subject to its validity, revocation, trust, and account-mapping conditions. This does not imply indefinite validity or absence of every residual directory artifact. The new controlled outcome in Section VI was measured on inventoried Windows Server 2016 VMs.

C. Protocol Discontinuity: PKCS#10 ASN.1 SAN Concealment and CA–KDC Logging Gap

Collecting both CA and KDC Security events does not necessarily supply a shared certificate key. The following projections describe selected observed fields, not a universal disjointness property of Windows event schemas.

Selected Captured Fields: The selected issuance fields shown in Listing 1 are

$$\pi_{\text{CA}} = \{\text{RequestId}, \text{Requester}, \text{Subject}, \text{Attributes}\}.$$

The certificate-bearing KDC record exposes

$$\pi_{\text{KDC}} = \{\text{TargetUserName}, \text{PreAuthType}, \text{CertIssuerName}, \text{CertSerialNumber}, \text{CertThumbprint}\}.$$

SKID and Disposition are not demonstrated in the selected issuance payload. Optional CA-database enrichment supplies the certificate identifiers used below. The important limitation is the lack of a shared certificate key in these captured fields, not the disjointness of arbitrarily selected field names.

SAN fields in requests and audit records: When an attacker requests a certificate with a rogue Subject Alternative Name (e.g., impersonating the Domain Administrator), the SAN attribute can be supplied through two distinct mechanisms:

1) **Explicit RPC Attribute String:** Passed via the `Attributes` string parameter of `ICertRequest::Submit` (e.g., `"SAN:upn=Administrator@domain.local"`). In this configuration, the CA security log explicitly populates the `Attributes` field in Event ID 4887.
2) **Raw PKCS#10 ASN.1 Binary Extension:** Embedded directly within the cryptographic Certificate Signing Request (CSR) under the `szOID_SUBJECT_ALT_NAME2` (`2.5.29.17`) extension attribute.

Our forensic investigation of live archived GOAD event streams reveals that when an attacker employs the PKCS#10 ASN.1 CSR extension (as executed natively by modern exploit tooling), the CA event log omits the SAN string entirely from the XML event payload:

Listing 1. Selected fields from the independent 2019 enabled-condition

```
<Event xmlns="http://schemas.microsoft.com/win
    /2004/08/events/event">
  <System>
```

```
    <Provider Name="Microsoft-Windows-Security-
        Auditing"/>
    <EventID>4887</EventID>
    <TimeCreated SystemTime="2026-11-10T10:53:51
        .393283900Z"/>
    <EventRecordID>20539</EventRecordID>
  </System>
  <EventData>
    <Data Name="RequestId">7</Data>
    <Data Name="Requester">Q1LAB\q1.enroller</Data>
    <Data Name="Subject">CN=q1.enroller</Data>
    <Data Name="Attributes">
CertificateTemplate:Q1Evidence
ccm:WIN-NA2FC16NO63.q1lab.test</Data>
  </EventData>
</Event>
```

Listing 1 contains a template and client-machine attribute, but no textual SAN UPN. The issued public certificate does contain the requested administrative SAN, and an exact-certificate successful KDC event independently checks its use. A query requiring a textual administrative SAN in this issuance event has no such input here; this is a concrete missing-field case, not a measured universal SIEM false-negative rate. The selected issuance event supplies a Request ID, while optional CA-database enrichment supplies SKID. In contrast, the certificate-bearing KDC record supplies issuer, serial, and thumbprint. The CA database export supplies the issuer-scoped bridge evaluated in Section VI.

III. CertGraph Static Architecture and Bilinear Gating

This section details the static detection layer of CertGraph (Figure 2), analyzes the theoretical failure of standard message passing on access control graphs, and introduces a bilinear compatibility formulation whose learned output must be distinguished from exact authorization reachability.

A. Heterogeneous Graph Attention Network (HetGAT)

Following graph-learning formulations [10, 11], CertGraph employs a multi-relational graph attention network. Let $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$ denote the initial feature vector of entity $v \in \mathcal{V}$. Vertices are first projected into a shared hidden space of dimension d:

$$\mathbf{h}_v^{(0)} = \mathrm{ReLU}\left(\mathbf{W}_{\phi(v)}^{(0)}\mathbf{x}_v + \mathbf{b}_{\phi(v)}^{(0)}\right) \tag{8}$$

where $\mathbf{W}_{\phi(v)}^{(0)} \in \mathbb{R}^{d\times d_{\phi(v)}}$ is a type-specific linear projection matrix.

At each layer $l \in \{1,\dots,L\}$, message passing aggregates relational representations across incoming edges $\mathcal{N}_r(v) = \{u \in \mathcal{V} \mid (u,v) \in \mathcal{E}, \psi(u,v) = r\}$:

$$\mathbf{h}_v^{(l)} = \sigma\left(\sum_{r\in\mathcal{R}_{\mathrm{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)} \alpha_{vu}^{(l)}\mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}\right) \tag{9}$$

where $\mathbf{W}_r^{(l)} \in \mathbb{R}^{d\times d}$ is the relation-specific weight transformation for relation $r \in \mathcal{T}_E$, and $\sigma(\cdot)$ denotes the ELU activation function. The relational attention coefficient $\alpha_{vu}^{(l)}$ assigns dynamic importance to edge (u,v) under relation r:

$$\begin{aligned}\alpha_{vu}^{(l)} &= \frac{\exp(z_{vu}^{(l)})}{\sum_{k\in\mathcal{N}_r(v)}\exp(z_{vk}^{(l)})},\\ z_{vu}^{(l)} &= \mathrm{LeakyReLU}\left(\mathbf{a}_r^\top\begin{bmatrix}\mathbf{W}_r^{(l)}\mathbf{h}_v^{(l-1)}\\ \mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}\end{bmatrix}\right).\end{aligned} \tag{10}$$

where $\mathbf{a}_r \in \mathbb{R}^{2d}$ is the parameterized attention vector for relation r, and $\|$ denotes vector concatenation.

B. Theoretical Analysis: Representation Collapse and Gradient Bounds

One limitation in pure neighborhood aggregation on directed multigraphs is the erasure of intrinsic attributes for leaf and intermediate nodes.

Theorem III.1 (Intrinsic Attribute Preservation and Gradient Lower Bounds)**.** Let $\mathcal{G} = (\mathcal{V},\mathcal{E},\phi,\psi)$ be a directed heterogeneous multigraph. Consider an L-layer pure relational aggregation model with no target-feature dependence in its aggregation coefficients, no biases, and $\sigma(\mathbf{0}) = \mathbf{0}$. For the residual bound, differentiate with respect to the common hidden input $\mathbf{h}_v^{(0)}$ and assume square compatible skip maps and differentiability. No lower bound for the raw type-projected features is asserted. These assumptions restrict the theorem; attention coefficients that depend on the target features can transmit those features even without a self-loop.

1) **Intrinsic Feature Erasure:** If $\mathcal{G}$ contains no explicit self-loops on template nodes ($v \notin \mathcal{N}_r(v)$ for all r), the first-layer representation $\mathbf{h}_v^{(1)}$ is conditionally independent of initial features $\mathbf{x}_v$:
$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \mathbf{0} \in \mathbb{R}^{d\times d_{\phi(v)}} \tag{11}$$
Furthermore, for any unprivileged source account u with in-degree $d_{\mathrm{in}}(u) = 0$, $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$.
2) **Guaranteed Gradient Lower Bound via Residual Skips:** When parameterized residual skip connections are introduced ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\mathrm{skip}}^{(l)}\tilde{\mathbf{h}}_v^{(l-1)}$) with $\sigma_{\min}(\mathbf{W}_{\mathrm{skip}}^{(l)}) > 0$, the Jacobian of the representation satisfies:
$$\sigma_{\min}\left(\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{h}_v^{(0)}}\right) \geq \prod_{k=1}^{L}\sigma_{\min}(\mathbf{W}_{\mathrm{skip}}^{(k)}) - \|\mathcal{J}_{\mathrm{graph}}(v)\| \tag{12}$$
where $\mathcal{J}_{\mathrm{graph}}(v)$ is the full derivative of all non-skip contributions, including their dependence through earlier residual states. Its norm must be measured or bounded for the particular model; a single path's weight product does not bound an arbitrary graph's aggregate derivative. When $\prod_{k=1}^{L}\sigma_{\min}(\mathbf{W}_{\mathrm{skip}}^{(k)}) > \|\mathcal{J}_{\mathrm{graph}}(v)\|$, initial feature sensitivity is strictly preserved:
$$\left\|\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{h}_v^{(0)}}\right\| > 0 \tag{13}$$

Proof. We establish the two claims sequentially:

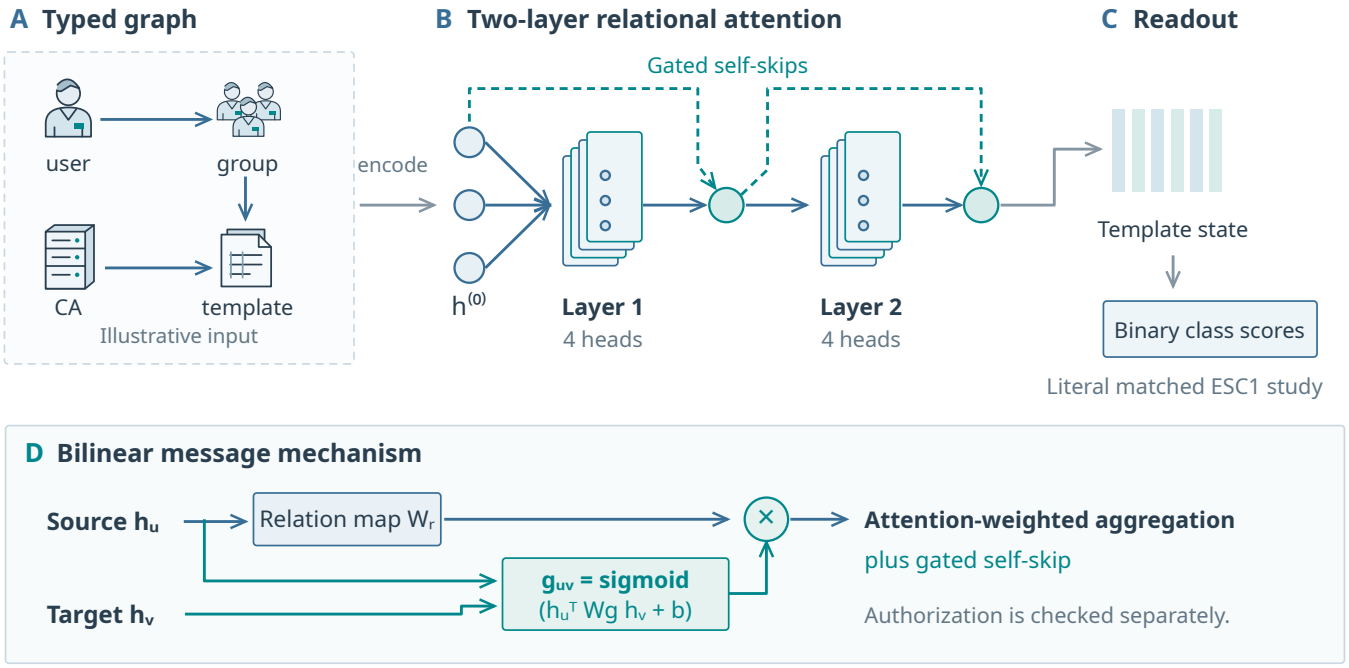


Fig. 2. CertGraph learning architecture and the literal bilinear mechanism. (A) Typed graph features enter (B) two relational attention layers with four heads per layer and gated self-skips, followed by (C) template readout and binary classification in the matched resolved-permission ESC1 study. (D) Source and target states determine a scalar bilinear gate that scales the transformed neighbor message before attention-weighted aggregation. Exact authorization is checked separately; the learned gate is not a Boolean reachability test. The input topology is illustrative.

Part 1: Intrinsic Feature Erasure under Pure Neighborhood Aggregation.: Under pure relational convolution at layer $l = 1$, the hidden state $\mathbf{h}_v^{(1)}$ is computed as $\sigma\left(\sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)}\alpha_{vu}^{(1)}\mathbf{W}_r^{(1)}\mathbf{h}_u^{(0)}\right)$. In an Active Directory multigraph, template nodes possess no explicit self-loops ($v \notin \mathcal{N}_r(v)$ for all r). Differentiating $\mathbf{h}_v^{(1)}$ with respect to the initial template feature vector $\mathbf{x}_v$ through its type-specific initial projection:

$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \sigma'(\cdot)\sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)}\alpha_{vu}^{(1)}\mathbf{W}_r^{(1)}\frac{\partial \mathbf{h}_u^{(0)}}{\partial \mathbf{x}_v} \tag{14}$$

Because distinct nodes possess independent initial feature vectors ($\partial\mathbf{h}_u^{(0)}/\partial\mathbf{x}_v = \mathbf{0}$ for all $u \neq v$), every term in the summation vanishes identically, yielding $\partial\mathbf{h}_v^{(1)}/\partial\mathbf{x}_v = \mathbf{0}$. Thus, the layer-1 embedding is conditionally independent of $\mathbf{x}_v$, discarding all intrinsic template configuration flags (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`). Moreover, for any source node u with in-degree $d_{\text{in}}(u) = 0$, $\mathcal{N}_r(u) = \emptyset$ for all r, so $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$ by empty summation and $\sigma(\mathbf{0}) = \mathbf{0}$.

Part 2: Gradient Lower Bounds via Parameterized Residual Skips.: With parameterized residual skip connections $\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)}\tilde{\mathbf{h}}_v^{(l-1)}$ and $\tilde{\mathbf{h}}_v^{(0)} = \mathbf{h}_v^{(0)}$, unrolling the recurrence across L layers yields:

$$\begin{aligned}\tilde{\mathbf{h}}_v^{(L)} &= \left(\prod_{k=1}^{L}\mathbf{W}_{\text{skip}}^{(k)}\right)\mathbf{h}_v^{(0)} \\ &+ \sum_{l=1}^{L}\left(\prod_{k=l+1}^{L}\mathbf{W}_{\text{skip}}^{(k)}\right)\mathbf{h}_v^{(l)}\end{aligned} \tag{15}$$

Differentiating $\tilde{\mathbf{h}}_v^{(L)}$ with respect to $\mathbf{h}_v^{(0)}$:

$$\begin{aligned}\frac{\partial\tilde{\mathbf{h}}_v^{(L)}}{\partial\mathbf{h}_v^{(0)}} &= \prod_{k=1}^{L}\mathbf{W}_{\text{skip}}^{(k)} + \mathcal{J}_{\text{graph}}(v), \\ \text{where}\quad \mathcal{J}_{\text{graph}}(v) &= \sum_{l=1}^{L}\left(\prod_{k=l+1}^{L}\mathbf{W}_{\text{skip}}^{(k)}\right)\frac{\partial\mathbf{h}_v^{(l)}}{\partial\mathbf{h}_v^{(0)}}\end{aligned} \tag{16}$$

By Weyl's singular value perturbation inequality and the submultiplicative property of singular values:

$$\begin{aligned}&\sigma_{\min}\left(\frac{\partial\tilde{\mathbf{h}}_v^{(L)}}{\partial\mathbf{h}_v^{(0)}}\right) \\ &\geq \sigma_{\min}\left(\prod_{k=1}^{L}\mathbf{W}_{\text{skip}}^{(k)}\right) - \|\mathcal{J}_{\text{graph}}(v)\| \\ &\geq \prod_{k=1}^{L}\sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\|\end{aligned} \tag{17}$$

Under the stated coefficient-independence assumptions, absence of every directed return walk to v within the evaluated depth implies $\mathcal{J}_{\text{graph}}(v) = \mathbf{0}$. Then the minimum singular value of the skip product is bounded below by the product of the

individual minimum singular values; equality is not generally implied. In cyclic or feature-dependent attention models, the non-skip derivative can reinforce or cancel the skip path. The positive-sensitivity conclusion therefore requires the displayed strict inequality and is not an unconditional guarantee for all GNNs. □

C. Shortcut Behavior and Bilinear Gating

While Theorem III.1 gives a conditional sensitivity bound for additive residual skips ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$), empirical testing reveals a secondary failure mode: *inductive shortcut collapse*.

The Shortcut Memorization Failure: Because certificate template attributes (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` = 1 and Client Authentication EKU = 1) are strongly correlated with positive escalation labels in synthetic training distributions, additive skip connections allow the network to bypass the multi-hop graph aggregation entirely. The MLP classification head learns an inductive shortcut:

$$\hat{y}_t = \text{MLP}(\tilde{\mathbf{h}}_t^{(L)}) \approx \text{MLP}\left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \mathbf{h}_t^{(0)} \right) \tag{18}$$

When the trained model is evaluated against **adversarial hard negatives**—templates that possess vulnerable attribute flags but reside in disconnected graph components or require mandatory manager approval—standard additive-skip GNNs memorize the flag pattern and classify them as vulnerable, showing poor agreement on the historical canonical generator. The matched audit in Section VI corrects its reachable-path labels and separates augmentation from implementation differences.

Multiplicative Bilinear Reachability Gating (`CertGraph-Gated`): To reduce shortcut memorization, we condition messages on a learned bilinear compatibility gate. The division between learned scoring and symbolic checking follows a broader neuro-symbolic design [12]. Exact reachability is checked separately by the existing symbolic verification step; the learned gate alone is not a Boolean authorization predicate. We formulate the **Multiplicative Bilinear Reachability Gate**:

$$\mathbf{g}_{uv}^{(l)} = \sigma\left(\mathbf{h}_u^{(l-1)\top} \mathbf{W}_g^{(l)} \mathbf{h}_v^{(l-1)} + b_g^{(l)} \right) \tag{19}$$

where $\mathbf{W}_g^{(l)} \in \mathbb{R}^{d \times d}$ is a bilinear interaction matrix, $b_g^{(l)} \in \mathbb{R}$ is a scalar bias, and $\sigma(\cdot)$ is the sigmoid function mapping to $(0, 1)$.

The gated message vector $\mathbf{m}_{vu}^{(l)}$ and state update are defined as:

$$\mathbf{m}_{vu}^{(l)} = \mathbf{g}_{uv}^{(l)} \odot \left(\mathbf{W}_r^{(l)} \mathbf{h}_u^{(l-1)} \right) \tag{20}$$

$$\begin{aligned} \mathbf{h}_v^{(l)} = \sigma\Bigg(& \sum_{r \in \mathcal{R}_{\text{in}}(\phi(v))} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} \mathbf{m}_{vu}^{(l)} \Bigg) \\ & + \mathbf{g}_{vv}^{(l)} \odot \left(\mathbf{W}_{\text{skip}}^{(l)} \mathbf{h}_v^{(l-1)} \right) \end{aligned} \tag{21}$$

where $\odot$ denotes the element-wise Hadamard product.

Proposition III.1 (Conditional Attenuation by Multiplicative Gating)**.** For a bounded transformed neighbor message, if its scalar gate tends to zero, multiplicative attenuation gives:

$$\lim_{\mathbf{g}_{uv} \to 0} \mathbf{m}_{vu}^{(l)} = \mathbf{0} \tag{22}$$

Disconnection alone does not imply this gate limit: with zero embeddings and zero bias, the sigmoid gate equals $1/2$. Other residual paths or classifier biases can also produce a positive output. The attenuation statement therefore does not prove universal elimination of shortcuts. The historical numerical implementation uses a feature-channel gate rather than this literal scorer. We now implement a separate two-layer, four-head realization of the displayed bilinear edge and self-skip equations and evaluate it with identical-initialization additive controls and matched augmentation (Table II). All relevant parameter families are trainable through autograd. The two implementations have identical held-out classifications in that new study, and both miss the positive long-path cases. This validates an auditable realization of the formulation, rather than a universal shortcut-elimination or authorization guarantee. A second-tier verifier must process unresolved and out-of-horizon cases, including neural negatives, if it is to recover those observed misses.

IV. Cryptographic Invariant Provenance Graph (CIPG)

To overcome the static snapshot blind spot and the CA–KDC schema discontinuity identified in Section II, we design the **Cryptographic Invariant Provenance Graph (CIPG)** (Figure 3). CIPG dynamically ingests raw Windows security audit event streams and CA transactional records, maintaining an asynchronous, taint-tracking automaton that bridges disconnected protocol layers.

A. Multi-Source Provenance Ingestion and Entity Resolution

CIPG processes heterogeneous audit streams across three disjoint operational layers:

1) **Directory Service Audit Events (NTDS):** Monitored via Windows Security Event ID 5136 (*Directory Service Object Modified*). Captures granular LDAP mutations on certificate templates, user objects, and access control lists, recording the modifying principal, target object GUID, modified attribute (e.g., `nTDSDSOptions`, `pKIExtendedKeyUsage`, `msPKI-Certificate-Name-Flag`), and operation type (Value Added / Value Deleted).
2) **Certificate Authority Telemetry and CA DB Bridge:** Monitored via Event IDs 4886 (*Certificate Request Received*) and 4887 (*Certificate Issued*). To supply the missing shared certificate identifiers, CIPG queries the local CA transactional database using `certutil`, requesting the `RequestID`, `SerialNumber`, `SubjectKeyIdentifier`, and `CertificateHash` fields, or the raw CA RPC interface. This populates a persistent cryptographic tuple:

$$\begin{aligned} \tau_{\text{crypto}} = \langle & \text{Issuer}, \text{RequestID}, \text{SKID}, \\ & \text{SerialNumber}, \text{Thumbprint}_{\text{SHA1}} \rangle \end{aligned} \tag{23}$$

3) **KDC Kerberos Pre-Authentication Events:** Monitored via Event ID 4768 (*Kerberos Authentication Ticket Requested*). Identifies PKINIT authentication requests where `PreAuthType = 16`, extracting the authenticating client name, domain target, certificate issuer CA, `CertSerialNumber`, and `CertThumbprint`.

B. Formal Cryptographic Invariants

CIPG evaluates incoming event sequences against five formal behavioral and cryptographic invariants:

Definition IV.1 (Invariant I: Two-Level Causal Invariant)**.** Let $e_{\text{mut}} \in \mathcal{E}_{\text{NTDS}}$ be a template ACL or attribute modification executed by principal u_{actor}, and let $e_{\text{req}} \in \mathcal{E}_{\text{CA}}$ be a certificate request submitted for template t. Invariant I is satisfied if:

$$\begin{aligned} & t(e_{\text{mut}}) < t(e_{\text{req}}) \\ \wedge \quad & \text{TargetObject}(e_{\text{mut}}) = t \\ \wedge \quad & \text{Requester}(e_{\text{req}}) \in \text{DelegatedPrincipals}(u_{\text{actor}}) \end{aligned} \tag{24}$$

Definition IV.2 (Invariant II: Temporal-Order Sequence Invariant)**.** For any valid certificate lifecycle, the sequence of events must satisfy strict monotone temporal progression:

$$t(e_{\text{mut}}) \le t(e_{\text{req}}) \le t(e_{\text{iss}}) \le t(e_{\text{auth}}) \tag{25}$$

This progression refers to effective operations. An audit timestamp inconsistent with it can also arise from clock error, audit delay, or an incorrect event association; it does not alone establish spoofing or replay. When these assumptions cannot be justified, the implementation retains a possible explanation or reports inconsistent evidence.

Definition IV.3 (Invariant III: Principal Identity Discrepancy)**.** Let $R = \text{Requester}(e_{\text{req}})$ be the Windows security principal submitting the certificate enrollment request, and let $A = \text{TargetIdentity}(e_{\text{auth}})$ be the Kerberos client identity authenticating with the resulting certificate. An identity escalation violation occurs if:

$$R \neq A \quad \wedge \quad \text{PrivilegeLevel}(A) > \text{PrivilegeLevel}(R) \tag{26}$$

Definition IV.4 (Invariant IV: Rollback Reversal Detection)**.** Let e_{mut} be an attribute modification on template t at time t_1 adding an insecure flag $\text{attr}_{\text{vuln}}$, and let e_{roll} be a subsequent modification at t_3 deleting $\text{attr}_{\text{vuln}}$. A rollback violation is triggered if:

$$\begin{aligned} & \Delta t = t_3 - t_1 \le \tau_{\text{window}} \\ \wedge \quad & \exists e_{\text{iss}} \in \mathcal{E}_{\text{CA}} \text{ s.t. } t_1 \le t(e_{\text{iss}}) \le t_3 \end{aligned} \tag{27}$$

where τ_{window} is the maximum temporal attack window (configured to 30 minutes in enterprise SOC policies).

C. Invariant V: Persistent Cryptographic Taint-Flow Automaton

While Invariants I–IV detect synchronous single-actor attacks, attackers can evade them via two evasive techniques: (i) **Split-Actor Collusion**, where Actor A mutates the template, Actor B requests the certificate, and Actor A rolls the template back; and (ii) **Dormant PKINIT Exploitation**, where the attacker delays Kerberos authentication by hours or days until the temporal correlation window τ_{window} has expired.

Algorithm 1 CIPG certificate-lineage update

Require: Event stream $\mathcal{S}$, CA bridge $\mathcal{B}$, taint table $\mathcal{T} \leftarrow \emptyset$
for each incoming event $e \in \mathcal{S}$ **do**
  if e.ID = 5136 and e.attr $\in \mathcal{A}_{\text{mut}}$ **then**
    Store the mutation in $\mathcal{M}$
  else if e.ID = 4887 and its template has an active mutation **then**
    Query $\mathcal{B}$ using issuer and request ID
    Add the resulting taint entry to $\mathcal{T}$
    Retain the certificate as a provisional overlap candidate
  else if e.ID = 4768 with success and pre-authentication type 15, 16 or 17 **then**
    Retain compatible candidates
    Reject candidates with a known identifier contradiction
    if one strongly identified candidate has justified issuance-before-use order **then**
      Emit the resolved lineage explanation
      Distinguish definite from possible mutation overlap
      Report mutator, requester and authenticated target
      Report authentication-minus-issuance latency
      Forward the supported explanation to remediation
    end if
  end if
end for

To retain certificate evidence beyond the immediate mutation window, we formalize the **Persistent Cryptographic Taint-Flow Automaton (Invariant V)**. Its conclusions depend on captured identity evidence and retained state; it does not guarantee detection over an unbounded history:

Algorithm notation: Let $\mathcal{A}_{\text{mut}}$ contain `nTDSDSOptions`, `msPKI-Certificate-Name-Flag`, and `pKIExtendedKeyUsage`. The mutation map $\mathcal{M}$ stores the object GUID, actor, time and operation. The CA bridge $\mathcal{B}$ returns the certificate identifiers for an issuer/request pair. A taint entry retains these identifiers, requester, mutation actor and issuance time.

Algorithm 1 illustrates the mutation-taint path. The identity reference also retains unmutated issuances and handles late enrichment and link revision; these broader behaviors are evaluated separately in Section VI.

Mathematical Guarantees and Operational Concurrency Realities: A serial number is scoped to its issuer [13]; SKID identifies a public key and can recur across distinct certificates. A thumbprint identifies certificate bytes, while an unauthenticated log field does not itself prove certificate possession or source integrity. The reference implementation requires all shared identity fields to agree and preserves compatible incompletely identified issuances, so missing fields cannot manufacture uniqueness. Late evidence can withdraw a previously resolved link. Retention enables delayed-use analysis only while the necessary observations remain available; no bounded-memory or irreversible-finality guarantee follows.

Bounded-time and source-fault reasoning: For opening, issuance, and rollback intervals O, I, R, definite temporal overlap requires $O^+ \le I^-$ and $I^+ \le R^-$. Otherwise, a feasible overlap remains possible. An exact difference-constraint reference additionally accepts explicitly justified operation-order edges [14, 15]; contradictory constraints yield an inconsistent-evidence answer. Cross-host record numbers do not supply those edges. This is an application of established temporal reasoning, with certificate-specific evidence requirements.

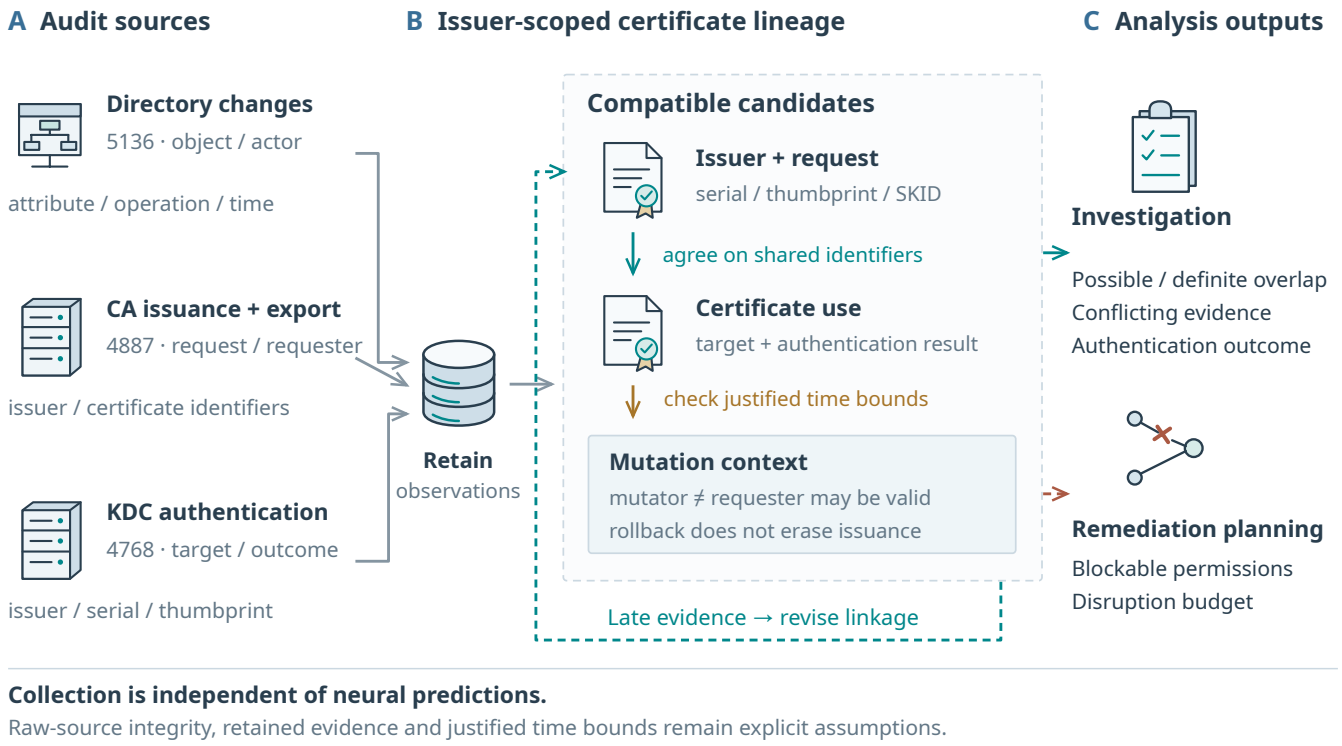


Fig. 3. CIPG evidence flow and revisable certificate lineage. (A) Directory changes, CA issuance/export evidence and KDC outcomes are retained independently of neural predictions. (B) Issuer-scoped identifiers, justified time bounds and mutation context support compatible lineage candidates; late evidence can revise a link. (C) Investigation reports overlap status, conflicts and authentication outcomes, while remediation planning retains its separate budget and immutability assumptions. Symbols denote logical roles rather than an observed deployment inventory.

For a declared optional-export fault budget k, let $\mathcal{H}_k$ contain every deletion of at most k CA bridge records. Candidate union over $\mathcal{H}_k$ preserves alternative explanations; a certain link must be resolved to the same issuance in every hypothesis. Abstaining hypotheses are retained, rather than removed to force agreement. If the true issuance is captured, raw issuance/KDC fields and time bounds are correct, and at most k bridge records are faulty, deleting those faulty records leaves a hypothesis containing the true candidate. This is a conditional retention property, not a claim of certain resolution or robustness to compromised raw audit sources. The exhaustive implementation is a correctness reference with combinatorial cost, and source-level compromise can invalidate a record-level budget [16, 17].

The earlier trace-driven synthetic stress stream illustrates two configured trade-offs; its rates do not measure a production deployment:

1) **Background Enrollment Collisions (False Positives):** The configured workload contains 50 maintenance windows with durations in $[10, 35]$ s and 2,000 renewals sampled uniformly over the simulated duration. Template selection, rather than the total renewal count, determines the candidate collision rate. Four maintenance windows produce false alarms: 8.00% maintenance-window FPR and 0.0395% overall event FPR, with 92.16% precision at $\Delta_{\text{poll}} = 5$ s and 92.31% at 1 s. Section VI states the actual sampling scheme; these are synthetic-workload counts, not an enterprise Poisson-rate measurement.
2) **CA Database Polling Latency (Simulated False Negatives):** The configured stress stream reports 48/48 recall at $\Delta_{\text{poll}} = 1.0$s and 47/48 at 5.0s. These outcomes use the stream's synthetic labels. They are separate from independently checking a successful issuance-to-use chain in captured Windows records; Section VI reports that evidence audit.

D. Graph Reduction and Meta-Node Compacting

Repeated authentication observations can make a provenance graph costly to retain and query. The legacy CIPG implementation groups repeated events into meta-nodes:

$$C : (v_{\text{event}}^{(1)}, v_{\text{event}}^{(2)}, \ldots, v_{\text{event}}^{(m)}) \mapsto \mathcal{V}_{\text{meta}} \tag{28}$$

Whenever repetitive, non-mutating events share identical source principals, destination templates, and access control rights within a sliding window, CIPG collapses them into a single directed meta-edge annotated with frequency counters and temporal bounding intervals $[t_{\min}, t_{\max}]$. As quantified in Section VI, this reduces graph storage overhead by **76.61%** (compressing 10,182 raw elements to 2,382 compressed elements) while consuming only 6.91 MB of memory at a sustained ingestion throughput of 13,192.4 events/second.

Correlated optional sources and self-consistent false order: Two explicit falsification controls test the boundaries of these guarantees. Six false bridge rows from one exporter exceed a two-record fault budget and produce a wrong certain

link. A sufficient six-record reference retains the true candidate with 64 hypotheses; a whole-source deletion reference retains it with two hypotheses under the different assumption of at most one faulty failure domain. It abstains from certainty, and requires an explicitly supplied source partition rather than treating file copies as independent origins. This is a failure-model comparison, not equal-budget accuracy superiority.

A second control supplies true times $o = 0$, $c = 1$, $i = 2$ inside declared bounds $[0, 3]$, then fabricates the jointly consistent order $o \le i \le c$. The temporal solver returns definite overlap although the latent history has none. Thus consistency checking cannot authenticate the order channel. The controlled orchestrator is an additional trusted source in our pilot; its truth assumption cannot be replaced by the mere absence of contradictory constraints.

V. Disruption-Budgeted Stackelberg Remediation Game

Detecting vulnerabilities is insufficient if remediation induces unacceptable operational friction. In this section, we formulate proposed permission-edge revocation as a leader–follower model between an enterprise defender and an optimal adversary, prove its computational hardness, and detail the co-adaptive interdiction algorithm.

A. Bilevel Stackelberg Game Formulation

We model the defensive interaction on the identity multigraph $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ as a non-cooperative Stackelberg game:

1) **Leader (Defender):** Moves first by selecting a subset of permission edges $E_{\text{cut}} \subseteq \mathcal{E}$ to revoke, subject to a maximum operational disruption budget $B_{\text{ops}} \in \mathbb{R}^+$.
2) **Follower (Attacker):** Fully observes the pruned graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ and executes an optimal, cost-minimizing attack path $p^* \in \mathcal{P}(\mathcal{G}')$ connecting an unprivileged foothold u_{source} to high-value target assets $\mathcal{T}_{\text{target}}$.

Heterogeneous Operational Revocation Costs: In enterprise Active Directory environments, revoking different permission types imposes vastly unequal operational disruption on legitimate business workflows. We assign heterogeneous cost functions $c : \mathcal{E} \to \mathbb{R}^+$ based on enterprise operational impact:

$$c(e) = \begin{cases} c_{\text{group}} \in [2.8, 3.8], & \psi(e) = \text{MemberOf}, \\ c_{\text{acl}} \in [2.0, 3.0], & \psi(e) \in \{\text{GenericAll}, \text{WriteDacl}\}, \\ c_{\text{choke}} \in [1.0, 1.4], & \psi(e) \in \{\text{Enroll}, \text{EnablesEnrollment}\}. \end{cases} \tag{29}$$

The assigned disruption labels are high for changes to user-role workflows, medium for changes to administrative synchronization, and low for template-enrollment reconfiguration.

The defender's optimization problem is formalized as:

$$\max_{E_{\text{cut}} \subseteq \mathcal{E}} \quad \mathcal{U}_{\text{def}}(E_{\text{cut}}, p^*(E_{\text{cut}})) = \sum_{i=1}^{k} \mathbb{I}\left[\text{Path}(s_i \rightsquigarrow t_i) = \emptyset \text{ in } (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})\right] - \lambda \sum_{e \in E_{\text{cut}}} c(e) \tag{30}$$

$$\text{subject to} \quad \sum_{e \in E_{\text{cut}}} c(e) \le B_{\text{ops}} \tag{31}$$

where $\mathbb{I}[\cdot]$ is the indicator function, $\lambda \ge 0$ is a regularizing trade-off parameter, and the follower's best response is:

$$p^*(E_{\text{cut}}) = \arg \min_{p \in \mathcal{P}(\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})} \sum_{e \in p} w_{\text{attack}}(e) \tag{32}$$

B. Computational Complexity: NP-Hardness of Multi-Principal Access Interdiction

We now prove that finding the optimal edge revocation strategy to neutralize multiple compromise paths under budget constraints is intractable.

Theorem V.1 (NP-Hardness of Multi-Principal Access Interdiction)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ be a directed identity multigraph with positive binary-encoded rational edge revocation costs and budget, and let $\mathcal{P}_{\text{forbidden}} = \{(s_1, t_1), \ldots, (s_k, t_k)\}$ be $k \ge 3$ source-target compromise pairs, with k part of the input. Pairs may share endpoints; no endpoint-disjoint restriction is asserted. The Multi-Principal Access Interdiction (MPAI) problem, which decides whether there exists $E_{\text{cut}} \subseteq \mathcal{E}$ with $\sum_{e \in E_{\text{cut}}} c(e) \le B_{\text{ops}}$ such that all paths in $\mathcal{P}_{\text{forbidden}}$ are severed, is NP-complete.

Proof. We establish membership in NP and provide a polynomial-time reduction from the NP-complete **Directed Multiway Cut** problem [18].

Part 1: Membership in NP.: Given a candidate cut set $E_{\text{cut}} \subseteq \mathcal{E}$:

1) We compute $\sum_{e \in E_{\text{cut}}} c(e)$ in $O(|E_{\text{cut}}|)$ time and verify the budget condition (31).
2) We construct the residual graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ in $O(|\mathcal{V}| + |\mathcal{E}|)$ time.
3) For each $(s_i, t_i) \in \mathcal{P}_{\text{forbidden}}$, we run Breadth-First Search (BFS) in $\mathcal{G}'$ starting from s_i to verify that t_i is unreachable in $O(k \cdot (|\mathcal{V}| + |\mathcal{E}|))$ time.

Because all checks execute in deterministic polynomial time, MPAI $\in$ NP.

Part 2: Reduction from Directed Multiway Cut.: Directed Multiway Cut takes a directed graph $H = (V_H, E_H)$, positive rational edge costs w, terminals $X = \{x_1, \ldots, x_q\}$, and budget W, and asks whether a cut of cost at most W removes every path between distinct terminals. This known NP-hard problem is a special source of interdiction instances; the complexity classification is not a new graph-theoretic discovery.

Retain every vertex and edge of H, with its original cost. For each terminal x_i, add distinct source and target copies s_i, t_i, with connector edges (s_i, x_i) and (x_i, t_i) of cost $W + 1$. Set

$$\mathcal{P}_{\text{forbidden}} = \{(s_i, t_j) : i \ne j\}, \qquad B_{\text{ops}} = W. \tag{33}$$

No budget-feasible cut can remove a connector. A path from s_i to t_j therefore exists exactly when a path from x_i to x_j remains in H, including paths passing through other terminals. Consequently, feasible cuts correspond with identical cost in both directions. The construction adds $2q$ vertices, $2q$ edges, and $q(q-1)$ forbidden pairs, and has polynomial encoding length. Together with polynomial verification of a

candidate cut and rational budget, this proves NP-completeness of the stated general pair problem. It does not establish a new hardness result for a fixed pair count or for a particular restricted AD graph family. □

C. Co-Adaptive Stackelberg vs. Static Greedy Interdiction

We compare simple degree-based and cost-aware static shortest-path-participation heuristics. The latter computes initial path participation divided by assigned edge cost once, so it already accounts for cost. Its limitation is the fixed ranking: earlier cuts can make later candidates redundant, and new shortest paths can change which permissions matter. The adaptive policy recomputes this information after each chosen cut. Degree-only ranking is a distinct baseline and need not have the same cost sensitivity. These are implemented research comparators rather than measured deployments of an industrial remediation product.

The evaluated **Co-Adaptive Stackelberg policy** is a sequential heuristic for the stated formulation. It recomputes active shortest paths and candidate marginal pair-disconnection gains, prioritizing assigned low-cost structural chokepoints (`Enroll` and `EnablesEnrollment` edges on the CA boundary, $c = 1.0$) that can sever multiple downstream escalation chains. This implementation is not a branch-and-cut solver and supplies neither a global optimum nor an equilibrium certificate. The reachability utility shown above does not depend on which surviving shortest path the follower selects; the experiments evaluate that reachability objective rather than a separately validated strategic equilibrium.

D. Operational Edge Immutability ($E_b \subsetneq E$) and Provenance-Cone Scalability

As considered in AD graph-hardening work [19], not all permissions can be revoked without breaking production workflows. A realistic fraction of permissions represents operational dependencies (e.g., core domain controllers, legacy service accounts, or administrative replication pipelines) where IT administrators enforce $e \notin E_b$ (`blockable = False`). Because of these immutable operational corridors, the metadata-preserving adaptive rerun reports $98.5 \pm 4.0\%$ disconnected pairs at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for static greedy). The saved paired t-test has $p = 0.0635$, while the historical asymptotic Wilcoxon test has $p = 0.0431$. Exact signed-rank enumeration gives $p = 0.0625$; the corrected eight-test Holm analysis in Section VI gives adjusted $p = 0.25$ for both procedures and does not support a significant budget-24 difference, leaving a measured mean residual of approximately 1.5% on those synthetic instances. This is not a proof that the residual is irreducible or that CIPG is its only possible defense.

The historical depth-limited cone timing compares fewer source–target queries with the whole-graph task. We replace that performance interpretation with a path-preserving projection evaluated on identical pairs in Section VI. Every pair endpoint and every vertex on a requested source–target path is retained, with unchanged edge attributes. This permits a meaningful comparison of the same reachability objective, including projection overhead, without treating a smaller query set as an algorithmic speedup.

Exact small-instance audit and metadata preservation: A fresh 60-case budgeted audit over 30 seven-node, twelve-edge graphs compares exhaustive feasible cuts with the historical adaptive heuristic, a metadata-preserving correction, and static greedy. The historical implementation removes a candidate edge and reinserts only its cost, losing its relation metadata during scoring. The corrected reference restores every attribute before continuing. It matches the optimal severed-pair count in 43/60 cases, compared with 46/60 for the historical version and 21/60 for static greedy, and has a maximum gap of two pairs. Correct metadata handling does not establish a performance improvement or an optimality guarantee. The original large-instance metrics remain historical results; they are not silently relabeled as measurements of the corrected reference.

VI. Empirical Evaluation and Live Cyber-Range Benchmarks

We conduct an empirical evaluation to validate CertGraph's static gating, dynamic provenance tracking, and game-theoretic interdiction. Specifically, we address four core research questions:

- **RQ1 (Shortcut Behavior):** How does multiplicative bilinear gating affect classification on hard negatives and long paths when initialization and augmentation are matched?
- **RQ2 (Provenance Validity):** Which rollback and split-actor certificate lineages are supported by captured Windows evidence, and how do incomplete identity fields, optional-source faults, and time uncertainty affect attribution?
- **RQ3 (Provenance Scalability):** What processing cost and compression are observed on the configured stress stream, and which retention and reasoning costs remain unresolved?
- **RQ4 (Budgeted Interdiction):** What pair-disconnection values, cut counts and optimality gaps does the sequential adaptive heuristic achieve relative to the implemented greedy comparators under assigned disruption costs?

A. Experimental Setup

Synthetic Identity Graphs: The historical static benchmark uses 700 class-balanced synthetic identity graphs. Additional graph sizes are used in the separate scalability experiments. Neither the class proportions nor the graph generator constitute a measured enterprise distribution. The new matched gating audit uses the existing two-step implementations with fixed source snapshots and separately recorded training, validation, and test inputs.

Live Cyber-Range Testbed: We use a virtualized Game of Active Directory (GOAD) cyber-range. Fresh inventory of the restored DC and CA identifies Windows Server 2016 Standard Evaluation, build 14393. That measured inventory supersedes the earlier draft's Server 2019 description. The two nodes are:

- `DC03` (`essos.local`): Active Directory Domain Controller, Kerberos KDC, and LDAP directory.
- `SRV03` (`braavos.essos.local`): Certificate Authority running Microsoft Active Directory Certificate Services.

The new split-actor case uses domain accounts ESSOS\khal.drogo and ESSOS\viserys.targaryen. Original disk images were read-only; execution used writable overlays. The capture pipeline runs non-interactively, while restoring the old VM images required console-assisted recovery. A second, independently provisioned forest uses Windows Server 2019 build 17763.4974, its own CA and ordinary enroller, and host-generated SHA-256-signed requests. This measured 2023 patch level is not described as a current patched configuration.

B. RQ1a: In-Distribution Ablations, Calibration, and Perturbation Asymmetry

We first distinguish the historical class-balanced generator from the newer attribution and live-policy experiments. Their labels, model implementations, and observation units differ.

Skip-Connection Ablation and Conditional Theory:: The saved five-fold artifact reports Macro-F1 0.9986 ± 0.0029 with skips and 0.4768 ± 0.0239 without skips. Recomputing the paired statistic from the five saved fold values gives $t = 46.245$, $p = 1.308 \times 10^{-6}$, and four degrees of freedom. The dispersions are population standard deviations across these folds. Shared training data and generator assumptions limit interpretation of this descriptive comparison. An empirical ablation does not validate the theorem outside its coefficient-independence and derivative assumptions.

Class Proportions and Probability Interpretation: The static experiments reported here are generator-based classification studies. Their balanced labels do not establish a 96% enterprise safe base rate, and their softmax scores are not calibrated probabilities of real-world compromise. We retain probabilities and selected checkpoints in the matched audit so that classification errors can be checked independently.

Perturbation Asymmetry and Simple Comparators: The saved robustness artifact gives Macro-F1 0.9479 after 30% edge perturbation, compared with 0.8965 and 0.7709 after 5% and 10% feature perturbation. This sensitivity pattern motivates testing structural counterfactuals; it does not prove that every prediction ignores topology. A separately verified, previously saved three-seed ESC13 abstraction also favors simple graph-count models over the existing GNN on its IID cases. Its symbolic reference defines the labels, so its perfect agreement is a consistency result rather than independent exploit validation.

C. RQ1b: Static GNN Generalization and Adversarial Hard Negatives

A source audit identifies two problems with interpreting the historical 41/63 safe-label agreement as a general hard-negative detection result. Ten "deep horizon" cases retain a membership path to an allowed enrollment group and therefore are positive under a transitive effective-permission interpretation. The stored 22 disagreements are eight administrator-only write cases, four deny-write cases, seven benign OID links, and three deep OID links; the earlier OID/CA explanation did not match that artifact. The canonical generator also repeats inputs across training and validation. These historical counts are retained in the artifact but do not establish independent-case specificity or a binomial confidence interval.

TABLE I
MATCHED TWO-STEP DIAGNOSTIC: 1,500 PAIRED CASES PER ARM (750 POSITIVE, 750 NEGATIVE). CORRECT CLASSIFICATION IS A PERCENTAGE; FALSE POSITIVES AND NEGATIVES ARE COUNTS. REPEATED TRAINING ARCHETYPES LIMIT THIS SYNTHETIC DIAGNOSTIC.

Implementation	Aug.	Correct	False positive	False negative
Additive	0	50.00%	750	0
Additive	0.3	71.67%	425	0
Feature-channel gate	0	70.00%	0	450
Feature-channel gate	0.3	70.00%	0	450

We therefore freeze and execute a matched 2×2 diagnostic: additive versus feature-channel-gated implementations, each with counterfactual augmentation probability zero or 0.3, across three new seeds. Model equations, propagation depth, and original artifacts remain unchanged. Each seed evaluates 250 opposite-label families, with membership depths 0, 1, 2, 4, and 8, randomized node order, and matched configuration features. Positive members retain reachable enrollment; negative members either restrict enrollment to the administrator or add a reachable explicit deny. Queue traversal and Boolean closure independently agree on all test labels under this stated ESC1 permission abstraction. CA trust and resolved permissions are assumed; Windows exploitability is not the label definition.

The gate gives zero false positives but misses all 450 positive cases at depths 2, 4, and 8 across the three seeds. Adding the same augmentation to the additive implementation improves its pooled accuracy from 50% to 71.67%, compared with the gate's 70%. Thus the audit does not establish superiority of gating over an augmentation-matched comparator. First-step membership transforms are fixed in these existing NumPy implementations, and their feature-channel gate is $\sigma(W_{\text{gate}}\mu_{\text{reach}} + b)$, rather than a literal implementation of the general bilinear edge scorer in Section III. Initialization also differs between implementations. These distinctions prevent attributing the entire contrast to a bilinear operation.

Only 22 unique training inputs occur per seed, with 21 also present in validation. Consequently, validation selection in this diagnostic is not an independent-distribution generalization test. All 6,000 saved test predictions are reproduced from saved checkpoints, and their labels and aggregates are checked independently. A symbolic second tier must also examine unresolved or out-of-horizon cases: verifying only neural-positive candidates cannot recover these observed neural false negatives.

Literal bilinear realization and family-disjoint validation: We address the implementation mismatch with a separate literal realization of the bilinear edge and self-skip equations: two relational-attention layers, four heads, 32 hidden channels, type-specific input projection, and fully trainable encoder, attention, skip, and gate parameters. The binary readout evaluates the stated ESC1 resolved-permission predicate, not observed Windows compromise. Additive and gated arms start with identical parameter values and receive matched

TABLE II
LITERAL TWO-LAYER ATTENTION: MEAN ACCURACY (%) ± SAMPLE SD OVER THREE SEEDS. EACH TEST COHORT CONTAINS 150 PAIRED FAMILIES PER SEED; INITIALIZATION AND AUGMENTATION ARE MATCHED.

Model	Aug.	IID	Long paths	Larger background
Additive attention	0	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Additive attention	0.3	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Bilinear attention	0	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00
Bilinear attention	0.3	86.00 ± 2.19	50.00 ± 0.00	87.00 ± 1.00

augmentation. Neither symbolic closure nor outcome labels enter the forward pass. Gradient, node-relabeling, and padding checks validate implementation properties; the historical implementations remain unchanged.

The new generator constructs varied reachable and unreachable membership branches and paired allow/deny interventions. For each of three new seeds, 300 training and 100 validation families are separated from 150 families in each of IID, long-path, and larger-background test cohorts. Typed five-round Weisfeiler–Lehman input hashes and family IDs are disjoint across splits within a seed. This conservatively excludes isomorphic whole inputs under the encoded roles and edge types, without claiming disjoint local motifs. Long-path positive enrollment chains have membership depth 2, 4, or 8. The larger-background cohort adds isolated nodes to different generated families; it is not a matched causal estimate of graph-size effects or enterprise-scale generalization.

Independent NetworkX reachability checks all 5,100 saved case labels, and checkpoint inference reproduces all 10,800 held-out predictions. The literal bilinear and additive models have identical classifications in every matched arm: IID accuracy averages 86.00% ± 2.19%, larger-background accuracy 87.00% ± 1.00%, and long-path accuracy 50%. In each arm, all 450 positive long-path cases are missed. Some IID negatives also require deny-membership reasoning beyond the local horizon; 126 pooled false positives remain. Probability scores differ, but their reported calibration errors concern these synthetic cohorts only. This closes the literal-implementation and repeated-whole-input gaps while failing to establish classification superiority for bilinear gating. Exact verification of unresolved cases remains necessary under the stated permission contract.

D. RQ2 & RQ3: Live Provenance Evaluation and Automaton Scalability

We separate seven archived trace files, one new outcome-checked Windows case, a synthetic attribution confirmation study, and the earlier 10,182-event trace-driven synthetic stress stream. Their outcome definitions and evidence levels differ; scenario filenames are not independent success labels. Dispersions are labeled by table: the literal-learning study reports sample SD across three seeds, whereas the finite-graph remediation study reports population SD. Neither is a confidence interval.

TABLE III
AUDIT OF SEVEN ARCHIVED GOAD FILES: 586 RAW EVENTS. LINKAGE CONCERNS THE CAPTURED CERTIFICATE ISSUANCE-TO-USE CHAIN. ATTACK RECALL IS NOT ESTABLISHED FOR ANY FILE.

Scenario	Events	Captured linkage
Normal enrollment	89	No consistent captured issuance
ESC4 rollback	90	No consistent captured issuance
ESC6 CA flag scenario	172	KDC failure result `0x42`
ESC9 UPN swap	94	No consistent captured issuance
ASN.1 SAN concealment	88	No consistent captured issuance
Admin typo rollback	6	No certificate-use observation
Split-actor scenario	47	Resolved observed linkage

TABLE IV
EARLIER TRACE-DRIVEN SYNTHETIC STREAMING BENCHMARK (10, 182 EVENTS, 48 GENERATED ATTACK INSTANCES, 50 SIMULATED MAINTENANCE WINDOWS). THESE ARE LEGACY IMPLEMENTATION RESULTS, NOT MEASUREMENTS OF THE NEW CONSTRAINT REFERENCE.

Pipeline	**Prec.**	**Recall**	**F1**	Maint. FPR	Event FPR
Snapshot rollback	19.35%	25.00%	21.82%	100.0% (50/50)	0.49%
CA event 4887	88.24%	58.33%	70.16%	0.00% (0/50)	0.00%
CIPG, default $\Delta_{\text{poll}} = 5$ s	**92.16%**	**97.92%**	**94.95%**	**8.00% (4/50)**	**0.0395%**
CIPG, fast $\Delta_{\text{poll}} = 1$ s	**92.31%**	**100.00%**	**96.00%**	**8.00% (4/50)**	**0.0395%**

TABLE V
2D SENSITIVITY MATRIX: PRECISION ABOVE RECALL (%) ACROSS CORRELATION HORIZON (Δt) AND CA JET DB POLLING LAG (Δ_{POLL}).

Window (s) FPR (%)	Poll 1 s	Poll 5 s	Poll 15 s	Poll 60 s
10	100.0%	100.0%	100.0%	100.0%
0.0	100.0%	97.92%	89.58%	89.58%
30	94.12%	94.00%	93.48%	93.48%
6.0	100.0%	97.92%	89.58%	89.58%
60	92.31%	92.16%	91.49%	91.49%
8.0	100.0%	97.92%	89.58%	89.58%
300	92.31%	92.16%	91.49%	91.49%
8.0	100.0%	97.92%	89.58%	89.58%
900	92.31%	92.16%	91.49%	91.49%
8.0	100.0%	97.92%	89.58%	89.58%

Collection delay and attribution trade-offs: As documented in Table IV and Table V, in the configured synthetic CA/KDC workload, operational performance is governed by two orthogonal systems dimensions:

- **Correlation Horizon (Δt) vs. False Positives:** The seeded generator places a fixed 2,000 renewal arrivals uniformly over the simulated duration T. A renewal chooses one of 15 maintenance templates with probability 0.055, uniformly among them; otherwise it chooses the machine template. It does not implement an unconditional 2,000-per-hour Poisson process. For a particular maintenance template and $\Delta \leq T$, the matching-arrival probability before additional principal or detector conditions is $1 - (1 - 0.055\Delta/(15T))^{2000}$. Thus the total renewal count is not the matching-event rate. The 50 generated maintenance windows have durations in $[10, 35]$ s. The saved sensitivity query observes 0/50 false alarms at 10 s, 3/50 at 30 s and 4/50 from 60 s onward. These are finite seeded-workload outcomes, not a general collision-free guarantee. The naive rollback monitor flags all 50 maintenance windows. Table V retains the observed precision and recall values.
- **CA Database Polling Lag (Δ_{poll}) vs. False Negatives:** Because KDC Event 4768 omits SubjectKeyIdentifier (SKID), linking Event 4887 to Event 4768 strictly requires CA Jet DB enrichment. When an attacker's PKINIT execution delay $\delta_{\text{pkinit}} \sim \text{LogNormal}(1.2, 0.8)$ executes before the next polling tick ($t_{\text{auth}} + \Delta_{\text{watermark}} < t_{\text{poll}}$), the join keys remain un-enriched at evaluation time, generating organic False Negatives. At $\Delta_{\text{poll}} = 1.0$s, CIPG achieves 100.00% recall (48/48). At default $\Delta_{\text{poll}} = 5.0$s, CIPG achieves 97.92% recall (47/48). At $\Delta_{\text{poll}} \in \{15\text{s}, 60\text{s}\}$, rapid attacks beat the polling cycle, resulting in 89.58% recall (43/48).

Ingestion Throughput and Memory Profiling: Under continuous streaming load:

- **Throughput:** The saved legacy benchmark reports **13,192.4 events/second** (771.81 ms) on the configured synthetic stream. This excludes a demonstrated end-to-end Windows collection/deployment pipeline and is not a throughput measurement of the new reference reasoners.
- **Memory Footprint:** The earlier result reports **6.91 MB**. A finite-run measurement does not establish bounded retained memory as the certificate history grows.
- **Meta-Node Compression:** Meta-node compacting collapsed 10,182 raw elements into 2,382 compressed elements, achieving a **76.61% reduction in graph size** without loss of topological taint information.

Outcome-checked split-actor pilot: The new capture contains 49 selected raw Security records. CA request 25 and issuance record 65102 identify the exact public certificate subsequently observed in successful KDC record 168295 (status zero, PKINIT type 16, domain Administrator SID ending in 500). The new certificate and exported private key were checked for identity before use; the original template flag was restored. A failed first capture is preserved and excluded. The configured delay was 14 seconds after the rollback step, not 24 hours. This establishes one controlled outcome, rather than an attack recall estimate.

The pre-capture clock-offset bracket fails a consistency check: the rollback audit timestamp precedes the host's rollback invocation under that constant-offset model. Point-time and assumed-error outputs therefore cannot establish guaranteed audit-time attribution. Separately, the frozen synchronous orchestrator records mutation completion before submission and retrieval of the exact issued certificate before rollback. Difference constraints over that additional operation-order channel establish controlled issuance between those operations without aligning the Windows audit clocks. Removing any one of the five required order edges returns a merely possible overlap. This does not establish when the CA consumed template policy, rule out every intervening mutation, or prove that the changed flag was necessary for issuance.

Locally frozen confirmation and component studies: The original constraint reference was frozen before a five-seed confirmation run containing 5,400 cases and 27,000 method/case predictions. Table VI reports the 2,000 variable-size histories separately from repeated logical challenges and forged-log controls. Compared with the conjunctive point-time baseline, the prototype makes fewer definitive claims: it resolves 55.82% rather than 74.56% of true observed links, retaining 99.06% in possible sets. It recovers 107 of 539 true mutation overlaps definitively with zero false overlap claims, versus 310 correct and 51 false claims for the point baseline. This is a coverage/certainty trade-off, not universal superiority. All 200 internally consistent forged-record controls defeat every method; truthful raw sources remain an explicit premise.

A separate source-hash-frozen factorial study uses 2,700 identity histories and 1,800 temporal histories from an independent component generator. The temporal solver agrees with 3,600 independently enumerated query answers. With a fully observed additional order channel, it recovers all 138 true overlaps in 300 histories; interval boxes recover 53 and point time recovers 112 with 11 false claims (Table VII). All 900 intentionally contradictory-order controls are rejected by the order-aware method. Complete observation is a designed upper-bound condition, not a measured enterprise sensor rate.

The bridge study tests zero to two faulty export records and fault budgets $k \in \{0, 1, 2\}$ (Table VIII). The $k = 2$ reference retains all 2,180 true links as candidates, but resolves only 602 certainly. Discarding all optional exports retains the same true links and resolves 1,757 certainly in this grid. The repair method therefore has no demonstrated advantage over that ablation here. Its exhaustive 49,800 hypotheses expose the cost of the fault contract and motivate testing independently corroborated enrichment, rather than claiming a solved robust-attribution problem. The artifact verifier checks latent labels, counts, hashes, temporal oracle answers, and within-budget retention; it does not prove optimality of repair candidate sets. None of these local comparators is an execution of Splunk or HADES.

Published-rule field-requirement replay: We also execute a SQLite candidate-association proxy for the SAN/principal conditions in Splunk's published ESC1 analytic [9]. This is not a Splunk runtime reproduction: scheduling, macros, default

TABLE VI
CONFIRMATION ON 2,000 SYNTHETIC HISTORIES: 1,804 TRUE OBSERVED LINKS AND 539 TRUE MUTATION OVERLAPS. LINK COVERAGE IS A PERCENTAGE; OVERLAP ENTRIES ARE EDGE COUNTS. THESE ARE ATTRIBUTION OUTCOMES, NOT EXPLOIT DETECTION RATES.

Method	Definite links (%)	Possible links (%)	True overlap	False overlap
Identifier OR	91.69	91.69	374	175
Issuer–serial	62.86	62.86	265	88
Conjunctive, 300 s	47.67	47.67	196	34
Conjunctive, point	74.56	74.56	310	51
CIPG constraint reference	55.82	99.06	107	0

TABLE VII
TEMPORAL COMPONENT STUDY, 300 HISTORIES PER OBSERVATION RATE. THE ORDER-AWARE METHOD RECEIVES AN ADDITIONAL EXPLICIT SENSOR CHANNEL; NO CROSS-HOST ORDERING IS INFERRED FROM RECORD NUMBERS. EACH ROW IS EVALUATED ON THE SAME CASES AS THE OTHER METHODS AT THAT RATE.

Order rate	Method	True overlaps	Recovered	False claims
0	Point time	122	93	18
0	Interval boxes	122	54	0
0	Intervals + observed order	122	54	0
0.5	Point time	148	104	12
0.5	Interval boxes	148	59	0
0.5	Intervals + observed order	148	88	0
1	Point time	138	112	11
1	Interval boxes	138	53	0
1	Intervals + observed order	138	138	0

join-result truncation, and multivalue behavior are outside the proxy. Seven archived files plus the new pilot contain only one issuance satisfying the textual SAN/UPN prerequisite, in the ESC6 file. Literal principal association returns no pair; an explicitly separate short-name normalization adaptation returns one pair whose KDC status is the failure value `0x42`. The new successful pilot lacks the textual SAN prerequisite. These results expose required evidence and normalization choices; they do not estimate Splunk's attack precision or recall or compare unlike task outputs as exact certificate linkage.

Repeated fixed-request policy interventions and executed external rules: We extend the initial pilot with a locally frozen 12-trial matrix and three repeated intervention blocks (Table IX). Within each block, baseline, enabled, and rollback-before-request conditions reuse identical signed CSR bytes and the same public key. Only the enrollee-supplied-subject bit changes; recorded template DACL, EKU, approval, signature, and OID fields remain equal. CA cache refresh and low-privilege RPC readiness checks are applied consistently. The enabled condition produces three exact-certificate Administrator authentications. Baseline and rollback-before-request conditions each produce three ordinary-user authentications, despite requesting the same administrative SAN. Three legitimate self-enrollments also authenticate as the ordinary user. All 12 outcomes are checked against public certificate bytes, CA database/4887 evidence, successful 4768 outcomes, target SID/name/domain, mutation evidence, and restoration. These controlled contrasts support necessity of the tested bit for the privileged outcome under the recorded conditions; they do not turn temporal overlap alone into a causal explanation.

TABLE VIII
BRIDGE-FAULT COMPONENT STUDY: 2,700 HISTORIES, 2,180 SUCCESSFUL OBSERVED LINKS. FAULT COUNTS RANGE FROM ZERO TO TWO; BUDGETS BELOW THE TRUE COUNT INCLUDE OUTSIDE-ASSUMPTION CONTROLS. CANDIDATE RETENTION AND CERTAIN-LINK COVERAGE ARE REPORTED SEPARATELY.

Method	Retained true links	Certain true links	Wrong certain	Hypotheses
$k = 0$	1440	721	0	2700
$k = 1$	1811	602	0	15300
$k = 2$	2180	602	0	49800
Ignore optional exports	2180	1757	0	2700

TABLE IX
MATCHED POLICY INTERVENTIONS: THREE BLOCKS PER OS AND THREE CERTIFICATE USES PER CONDITION. THE 2019 BUILD IS 17763.4974. SIGNED ADMINISTRATIVE CSR/KEY PAIRS ARE MATCHED WITHIN BLOCKS. ESC1 AND RISKY EKU MEASURE TEMPLATE CONFIGURATION, NOT ATTACK INTENT.

OS	Condition	Trials	Self	Admin	ESC1	Risky EKU
2016	Baseline/admin request	3	3	0	0	0
2016	Subject bit enabled	3	0	3	3	3
2016	Rollback before request	3	3	0	0	0
2016	Legitimate self request	3	3	0	3	3
2019	Baseline/admin request	3	3	0	0	0
2019	Subject bit enabled	3	0	3	3	3
2019	Rollback before request	3	3	0	0	0
2019	Legitimate self request	3	3	0	3	3

Earlier development attempts remain in the artifact: the first matrix contains two RPC failures among 12 attempts, and the initial fixed-CSR collector stops on a Windows pending-request-store binding failure in its second trial. Those are infrastructure failures, not policy negatives. The corrected collector explicitly binds the verified held key to the exact new certificate and refuses unrelated keys; it never substitutes a prior certificate. The final fixed-CSR matrix is reported separately. Its Windows-generated requests use their observed SHA-1 signature algorithm, verified explicitly, rather than being relabeled modern SHA-256 requests.

Certipy 5.0.4 is executed against LDAP for each assigned configuration using its DC-only mode. Three unmodified upstream Sigma rules [20] are compiled by pySigma 2.1.0/SQLite backend 2.1.1 and executed on the captured event fields. Template-load events 4898 supply the actual tested-template configuration. Both Certipy's ESC1 finding and Sigma's risky-EKU predicate identify all three enabled administrative conditions and all three enabled legitimate-self conditions, with no tested-template match in baseline or rollback-before-request conditions. That agreement con-

cerns risky configuration, not malicious intent: legitimate self-enrollment does not become an attack false positive merely because its template remains risky. Sigma matches on other loaded templates are retained separately. The machine-account rule has no matching human-account target. This is an actual external-rule/tool execution, separate from the earlier Splunk semantic proxy and from a full SIEM or HADES deployment.

Independent forest replication and measured collection cost: We repeat the four-condition matrix in a newly provisioned `q1lab.test` forest, with its own `Q1-Evidence-CA`, ordinary `q1.enroller` account, separate template, and host-generated SHA-256-signed CSRs. All 12 exact-certificate outcomes are verified: three enabled-condition Administrator uses and nine self-uses. Three matched signed-request/policy blocks reproduce the controlled contrast. Some restoration value-addition events are absent despite successful write responses and restored readback; certificate-use validation and complete mutation-audit history are therefore reported separately. The measured build, 17763.4974, predates current strong-binding enforcement updates [3]. An earlier interrupted collection with a four-hour clock difference is preserved as a failed setup attempt, not counted as a policy or detection result.

On the independent captures, raw template names and CA database template OIDs initially disagree, causing the identity reference to abstain in all 12 cases. Adding the collected directory object's explicit OID/name mapping resolves all 12 identities, with three privileged SID divergences and nine nonprivileged outcomes. Certificate/CSR bytes and adjudicator labels remain excluded from inference. The initial abstentions are retained as development results; the mapping adjustment is not presented as untouched held-out performance. Actual Certipy/Sigma configuration-risk results repeat the Windows 2016 pattern in the independent forest.

The median recorded command envelope is 50.91 s per trial on the two-node 2016 setup and 32.14 s on the single-node independent 2019 setup. Ten offline identity-inference repetitions per captured trial give medians across trials of 10.99 ms and 9.18 ms, respectively. Python-traced peak allocations are approximately 1.74 MB and 1.50 MB at the median. These measurements describe the captured experiment and offline inference; they do not measure continuous polling delay, host RSS, or enterprise authentication interference.

Current-patch request forms and post-rollback observation: We update the independent forest using signed Microsoft packages to Windows Server 2019 build 17763.9376 (October 2026 security update KB5126651 [21]). Post-reboot inventory verifies the installed build, no pending reboot, running CA/KDC services, an ordinary enroller, and enabled Defender. No binding-compatibility override is introduced. Two locally frozen 12-trial protocols repeat the four conditions with UPN-only and UPN-plus-SID-URL requests. Administrative requests reuse identical signed CSR bytes and keys within each block and request form; keys are not matched across forms. The SID URL follows the documented Microsoft mapping format [22]. All conditions now include restored template readback, CA refresh, RPC readiness and actual Certipy enumeration before authentication. These additional controls differ from the older-build workflow, so the old/new contrast is not an isolated patch-only experiment.

TABLE X
CERTIFICATE OUTCOMES ON WINDOWS SERVER 2019 BUILD 17763.9376: THREE TRIALS PER CONDITION AND REQUEST FORM. REJECT DENOTES A CERTIFICATE-BOUND KDC REJECTION. ESC1 PRE/POST ARE CONFIGURATION FINDINGS BEFORE REQUEST AND AFTER ROLLBACK. MISSING CA EXPORTS AND LATER SNAPSHOT ADJUDICATION ARE DESCRIBED IN SECTION VI.

Request form	Condition	Self	Admin	Reject	ESC1 pre	ESC1 post
UPN	Baseline	3	0	0	0	0
UPN	Enabled	0	0	3	3	0
UPN	Rollback first	3	0	0	0	0
UPN	Self request	0	0	3	3	0
UPN + SID URL	Baseline	3	0	0	0	0
UPN + SID URL	Enabled	0	3	0	3	0
UPN + SID URL	Rollback first	3	0	0	0	0
UPN + SID URL	Self request	3	0	0	3	0

The UPN-only matrix yields six verified ordinary-user authentications and six certificate-bound KDC rejections: all three enabled administrative requests and all three enabled legitimate-self requests are rejected. The six rejected public certificates lack the security SID extension and match KDC System event 39 by serial and thumbprint. Baseline and rollback-before-request certificates contain the enroller SID extension and authenticate as that user. With a matching SID URL, all 12 outcomes authenticate: three enabled administrative uses and nine self-uses. The enabled certificates contain the requested SID URLs and lack the security SID extension. Three fixed-request/policy blocks support the conditional enabling-bit contrast for this form; no such privileged-use contrast is observed for UPN-only requests. These observations accord with the documented distinction between weak names and strong certificate mapping [3, 22]; adding a SID URL is not a new exploitation technique.

Actual Certipy and Sigma executions retain the same pre-request risky-configuration pattern in both matrices. All 24 post-rollback Certipy enumerations cease flagging ESC1 on the tested template, including the three cases that subsequently authenticate as Administrator. This demonstrates that restored configuration and the later usability of an issued certificate are different questions. It does not establish attack intent or superiority over a provenance system given equivalent certificate evidence. The unchanged identity reference links all 18 successful current-patch authentications, including three privileged SID divergences, without certificate/CSR bytes or adjudicator labels as inference inputs. Rejected authentications are outside this successful-use linkage denominator.

The first adjudication preserves a collector defect: an empty System-log query prevented the following CA database export in 18 trials. A separately recorded later read-only CA snapshot supplies only those missing exports in ephemeral verification views; all original captures and manifests remain unchanged. Matching public certificate bytes, CA rows, trial issuance events and KDC evidence then resolves all 24 outcomes. This later snapshot does not establish historical template state

TABLE XI
IDENTITY PROJECTION ON 1,410 HISTORIES, INCLUDING 60 CHRONOLOGY-NEGATIVE CONTROLS, WITH 1,241 TRUE OBSERVED LINKS. EVENT TIMES ARE ERASED. THE 60 WRONG TERMINAL CLAIMS PER METHOD ARE CHRONOLOGY CONTROLS; 60 SEPARATE FORGED-SOURCE CONTROLS ALSO FOOL EVERY METHOD. THESE ARE IDENTITY-QUERY OUTCOMES, NOT FULL PIDS DETECTION.

Method	Resolved	Correct	Wrong	True candidates retained
CIPG identity	820	760	60	1176
SQL strong join	912	852	60	852
SQL guarded	820	760	60	1176

TABLE XII
PROSPECTIVE NEW-FOREST WORKLOAD: 24 CERTIFICATES IN SIX CONCURRENT BATCHES, TWO TEMPLATES AND TWO ENROLLERS. CONFIGURATION COLUMNS COUNT FOUR TEMPLATE/BATCH/ENROLLER UNITS PER CONDITION, SHARED BY EIGHT CERTIFICATE CASES. THE WINDOWS IMAGE FAMILY IS SHARED WITH THE PREVIOUS ENVIRONMENT.

Condition	Cases	Self	Admin	ESC1 pre	ESC1 post	Risky EKU
Baseline	8	8	0	0	0	0
Enabled	8	4	4	4	0	4
Rollback first	8	8	0	0	0	0

or repair the audit-clock model. A live empty-query control validates the collector correction before the restored lab is shut down. Across the four final matrices, 48 trials therefore provide 42 successful exact-certificate authentications, including nine administrative uses, and six exact-certificate rejections.

Equal-input relational realization and revision: We execute two SQLite correlators on the same canonical observations as the identity reference. A strong conjunctive join resolves a unique strong, nonconflicting match; a guarded query also retains incomplete candidates and relevant conflicts. All event intervals are projected to $[0, 0]$, with no mutation windows, so this experiment concerns identity and revisions rather than temporal attribution. Across 1,470 newly seeded histories, the guarded query and reference agree at all 5,423 evaluated prefixes. Independent set-based verification checks 16,269 prediction rows and 450 saved latent random-history labels. Both methods retract 225 provisional resolved links during shuffled delivery and bridge removal/reinsertion. This establishes relational realizability of the contract; the query is our implementation in SQLite, not an execution of HADES or Splunk.

The main 1,410-case group includes 60 chronology-negative controls, which produce wrong terminal claims in every identity-only method because time was erased. A separate 60 consistently forged-source controls also fool every method. The guarded contract retains more true candidates but resolves fewer correct links than the strong join on this challenge. We therefore do not claim unique reasoning power or universal superiority over a competent relational implementation. Candidate completeness, temporal evidence and source truth remain separate requirements.

Prospective concurrent transfer to a new forest: Before collection, we freeze the unchanged identity detector and a new workload protocol. A writable child of the updated Windows image is demoted and reprovisioned as `q1transfer.test`, with a fresh domain SID, hostname, CA, two templates and two ordinary enrollers. The seed and original disk mounts remain read-only. This transfers identity namespaces and workload conditions while sharing the Windows image family. Six batches each issue four certificates through overlapping enrollment command envelopes. Each enroller reuses one RSA key across its certificates, with identical signed request bytes within each enroller/target group. These are repeated issuances with reused keys, not a Windows renewal-protocol experiment.

All 24 distinct public certificates match their CSR keys, CA issuance and successful KDC outcomes: 20 self-uses and four administrative uses. Every batch has four overlapping submission command envelopes; that does not prove simultaneous CA execution. All 24 leaf signatures verify under the separately captured public CA certificate, whose current NTAuth membership is observed. The frozen detector links all 24 successful uses, including four privileged SID divergences. A later adjudicator reporting fix leaves legacy mutation-history fields unvalidated for the new condition names; certificate-use criteria and labels are unchanged. Actual Certipy/Sigma findings are counted in 12 distinct template/batch/enroller units, since two certificate cases share each enumeration. All 12 postrollback enumerations cease flagging tested-template ESC1. The six batch exports contain 4,544 Security events, including process creation/termination, explicit credentials and service-ticket events. They are not full Sysmon/file/socket provenance for an end-to-end PIDS comparison.

TABLE XIII
PAIRED ISOLATED-LAB PILOT; EIGHT VERIFIED AUTHENTICATIONS PER ARM. AUTH IS THE MEDIAN CERTIPY PROCESS ENVELOPE (MS); CPU IS PYTHON COLLECTOR CPU TIME (MS). RSS IS PYTHON COLLECTOR MIB, EXCLUDING CHILDREN AND THE WINDOWS VM. VERIFICATION WAITS FOLLOW TIMING.

Pair	Arm	Verified uses	Auth (ms)	CPU (ms)	RSS (MiB)
1	polling	8	687.8	664.3	56.5
1	idle	8	639.2	85.1	58.6
2	polling	8	702.0	672.3	59.4
2	idle	8	622.0	85.9	59.2
3	idle	8	602.9	88.6	59.4
3	polling	8	703.2	664.7	59.5

Paired collection and authentication-envelope pilot: A separately frozen pilot compares periodic collection with an idle collector in three seeded arm orders on the restored transfer forest. Each arm performs eight legitimate certificate authentications at a three-second target start period. Polling targets two seconds, exports incremental Security records and the CA database, updates the identity reference and retains checkpoints. Independent public-certificate/KDC checks validate all 48 measured authentications. Median authentication process envelopes increase by 48.6, 80.0 and 100.3 ms in the three pairs. These include Certipy startup and network work; they are not packet-level KDC latency or a production interference bound.

The 33 polling iterations have per-arm median collection-plus-reasoning envelopes of 1.586–1.659 s. Sampled Python collector RSS ranges from 56.5 to 59.5 MiB across arms,

excluding Certipy children and the Windows VM. Periodic reference state grows from 30 seeded records to 37 records, with a 16,000-byte final checkpoint in each polling arm. This short pilot does not establish bounded lifetime retention or maximum sustainable throughput. An initial run exported outcome evidence too early and undercounted final idle-arm records; it is retained separately. The corrected run waits for outcome verification after the measured interval, preserving the authentication timing denominator.

E. RQ4: Game-Theoretic Stackelberg Remediation Performance

We evaluated our Co-Adaptive Stackelberg policy against three standard remediation baselines across 30 generated identity graphs:

1) **Random Cut:** Selects arbitrary reachable edges within budget.
2) **Degree Centrality:** Selects edges incident to the highest-degree nodes.
3) **Static Greedy:** Ranks participation in initially selected shortest paths once, divided by assigned revocation cost, then cuts feasible edges in that order.
4) **Co-Adaptive Stackelberg (Ours):** Applies the sequential reachability heuristic to the interdiction formulation under heterogeneous operational disruption costs and operational edge immutability ($E_b \subsetneq E$).

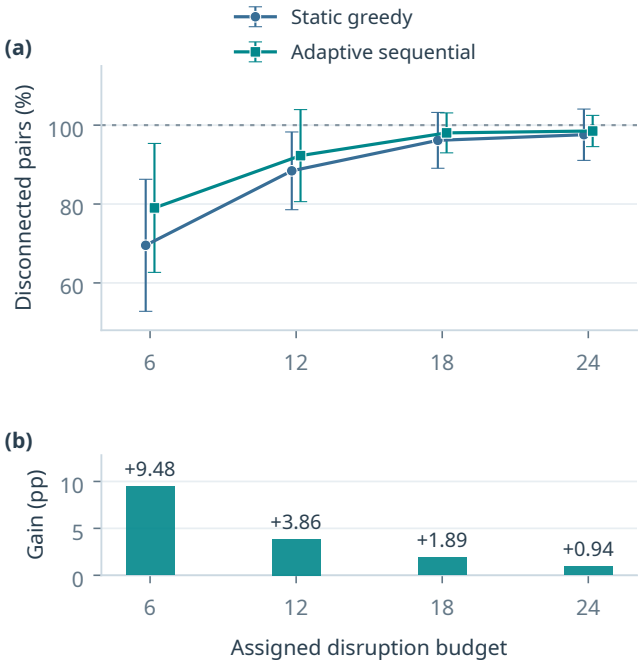


Fig. 4. Remediation on the same 30 generated graphs as Table XIV: (a) mean disconnected-pair percentages with population SD bars and (b) mean adaptive-minus-static gain in percentage points (pp). The dashed line marks 100%; symmetric SD bars are descriptive and can extend above that bound. The horizontal axis is assigned disruption cost. These are fixed-budget comparisons rather than equilibrium trajectories.

Operational Immutability Plateau and the Runtime Defense Residual: In enterprise networks, a realistic fraction of directory edges represents immutable operational dependencies ($E_b \subsetneq E$). As shown in Table XIV and Figure 4, proactive graph interdiction achieves 98.5±4.0% paths severed at $B_{\text{ops}} = 24$ (vs. 97.6±6.5% for Static Greedy). This experiment leaves a mean residual of approximately 1.5% under the selected graph instances, budgets, and non-blockable edges. It does not prove that every enterprise has an unavoidable residual of that size or that a different feasible policy cannot disconnect all modeled paths. Runtime monitoring is complementary to the evaluated hardening policies.

Exact paired sensitivity and multiple comparisons: Recomputing all saved per-topology statistics reproduces the historical values. At budget 24, only five of 30 paired differences are nonzero, all positive, with mean gain 0.94 percentage points. Exact signed-rank sign-flip enumeration over $2^5 = 32$ assignments gives two-sided $p = 0.0625$, compared with the historical asymptotic Wilcoxon $p = 0.0431$ and paired t-test $p = 0.0635$. The historical eight-test Holm analysis [23] leaves only budget 6 below 0.05. We rerun the original 30 graphs at all four budgets with full edge-attribute restoration. Independent adjacency-list checks validate 120 cut/budget outcomes and 11,100 reachability queries, while reproducing all 120 historical adaptive and 120 static-greedy percentages. The correction changes nine disconnection outcomes and 24 cut counts. Table XIV uses the corrected row and a fresh eight-test family: budget 6 survives both procedures, budget 18 survives only exact signed rank (adjusted $p = 0.02344$, paired-t adjusted $p = 0.05138$), and budget 24 survives neither (both adjusted $p = 0.25$). Exact ranks use rational disconnection fractions and omit zero differences. These are descriptive reanalyses of the saved synthetic-graph study, not evidence of enterprise operational superiority.

Corrected Revoked-Edge Count: Under $B_{\text{ops}} = 24$, Static Greedy revokes an average of **10.9 edges** (10.9 ± 0.9), under the assigned heterogeneous costs. The saved summary does not measure the resulting business-workflow disruption. The metadata-preserving adaptive rerun revokes an average of **5.7 edges** (5.7 ± 2.3), a **47.7% reduction in revoked-edge count**. The historical implementation used 6.0 edges on average; its source, results and retained visualization remain labeled historical. The disruption weights are assigned model parameters; actual administrator effort and business disruption were not measured.

Scalability via Provenance-Cone Guidance: The historical depth-limited cone benchmark drops some queried source–target pairs. Its nominal $N = 5,000$ graph actually contains 4,551 nodes, and its $1,246.3\times$ timing ratio compares different pair tasks. It therefore does not establish equal-task solver acceleration or online response latency.

We implement a path-preserving projection instead. For every requested pair (s, t), retain the intersection of vertices reachable from s and vertices that can reach t, together with every pair endpoint. Every original s–t path is retained, so subsequent removal of any retained edge subset preserves that pair's reachability answer. Edge costs, relations and immutability are copied unchanged, and initially unconnected endpoints

TABLE XIV
REMEDIATION ON THE SAME 30 GENERATED IDENTITY GRAPHS. THE ADAPTIVE ROW USES FULL EDGE-ATTRIBUTE RESTORATION. MEAN AND POPULATION SD DESCRIBE THE FINITE EVALUATED SET. TESTS COMPARE THE CORRECTED ADAPTIVE POLICY WITH STATIC GREEDY; HOLM CORRECTION COVERS FOUR BUDGETS AND TWO TEST PROCEDURES.

Policy	Budget 6	Budget 12	Budget 18	Budget 24
Random cut	12.0 ± 7.3%	14.0 ± 10.5%	12.2 ± 8.1%	11.5 ± 7.4%
Degree centrality	52.6 ± 24.7%	69.1 ± 16.9%	77.2 ± 15.4%	83.6 ± 14.1%
Static greedy	69.5 ± 16.7%	88.4 ± 9.9%	96.1 ± 7.1%	97.6 ± 6.5%
Metadata-preserving adaptive	79.0 ± 16.3%	92.3 ± 11.7%	98.0 ± 5.1%	98.5 ± 4.0%
Paired t, raw p	4.074×10^{-6}	0.07562	0.01028	0.0635
Exact signed rank, raw p	9.537×10^{-7}	0.06465	0.003906	0.0625
Holm paired t	2.852×10^{-5}	0.25	0.05138	0.25
Holm signed rank	7.629×10^{-6}	0.25	0.02344	0.25

TABLE XV
EQUAL-QUERY PROJECTION TIMING (MS), INCLUDING PROJECTION CONSTRUCTION. THREE GRAPH SEEDS AND FIVE ALTERNATING-ORDER REPETITIONS PER SEED; ALL SEVERED-PAIR OUTCOMES AGREE. HIERARCHICAL SYNTHETIC GRAPHS, SHARED HOST.

Nodes	Queried pairs	Full (ms)	Projection + solve (ms)	Median ratio
100	6	1.99	1.16	1.78×
1,000	65	86.36	21.56	4.01×
5,000	325	3448.15	439.29	7.54×

remain represented. Intersecting any full-graph cut with the retained edge set removes no requested-path effect and cannot increase its nonnegative cost, so the optimal budgeted pair-disconnection value is also preserved. A heuristic's selected cut can still depend on its search order. Shared endpoint closures are computed once per distinct endpoint.

The new benchmark retains all pairs, uses the same historical heuristic on full and projected graphs, and includes projection cost (Table XV). At 5,000 actual nodes and 325 queried pairs, 874–890 nodes remain. Across fifteen alternating-order timing pairs, the median per-run ratio is 7.54×, with observed range 6.62–8.99×, and severed-pair outcomes agree in every run. The median full and projection-inclusive times are 3,448.15 ms and 439.29 ms; their ratio need not equal the median of individual ratios. This controlled result is narrower than the historical headline and does not supply an optimality or enterprise workload guarantee.

VII. RELATED WORK

Active Directory and PKI Security: The BloodHound software models identity relationships for privilege-path investigation. SpecterOps [2] systematized ADCS misconfigurations; Certipy [4] supports certificate-service assessment. A restored configuration snapshot alone cannot reveal every intervening issuance. However, practical CA/KDC correlation is established: In.security describes SAN-abuse investigation in KQL [8], and Splunk publishes an ESC1 authentication analytic [9]. CIPG therefore does not claim novelty for joining issuance and authentication events. Its research question concerns certificate-specific identity consistency, possible versus definite answers, and revision under incomplete or conflicting evidence.

Graph learning and shortcut behavior: Graph neural networks aggregate information over relationships. The original graph model and later reviews describe the assumptions and model families behind this approach [10, 11, 24]. Convolutional graph models are reviewed by Wu et al. [11]; the attention construction follows GAT [25]. Euler studies temporal link prediction for lateral movement [26]; its task differs from our resolved-permission predicate. Shortcut learning [7] and adversarial robustness [27] motivate testing structural counterfactuals. Neither literature establishes that the bilinear gate used here improves classification. Our matched experiment finds no such improvement.

Provenance and incomplete evidence: Surveys describe provenance capture, dependency growth and security analysis [28, 29]. HADES addresses whole-network AD investigation [5], while CPD examines persistence [6]. These are related investigation systems, not executed baselines in this study. Established work on order-incomplete queries [15], temporal constraints [14], and record matching [16] supplies broader reasoning foundations. Record matching alone does not guarantee correct attribution under compromised logs. Our contribution is the certificate-specific evidence contract and its evaluated boundaries, rather than a new general entity-resolution or temporal-query primitive. The time-model preprint [17] is retained as a clearly identified technical source.

Interdiction and remediation: Attack-graph analysis includes reachability, cost and uncertainty models [30]. Goel et al. evaluate evolutionary policies for hardening AD graphs [19]. Security games provide a broader decision framework [31]; known cut problems provide the complexity foundation [18, 32]. Our formulation adds assigned disruption costs and immutable edges to the evaluated instances. It does not establish a new general hardness result or certify an optimal remediation policy. The exhaustive small-instance comparison instead measures where the sequential heuristic falls short.

VIII. DISCUSSION AND LIMITATIONS

A. Collection Cost and Deployment Scope

The legacy synthetic replay reports 13,192.4 events/sec and 6.91 MB on a fixed stream. Those measurements do not establish zero interference with domain authentication, bounded history storage, or end-to-end CA polling cost. The lineage reference recomputes retained evidence, and the fault-budget

reference enumerates deletion hypotheses. The recorded live command envelopes and offline inference timings quantify two parts of this cost: median recorded trial envelopes are 50.91 s and 32.14 s in the two environments, while median offline identity reasoning is 10.99 ms and 9.18 ms. A three-pair collection pilot measures periodic export/reference updates and verifies 48 legitimate authentications. The paired median client process-envelope increases are 48.6–100.3 ms, with sampled Python collector RSS of 56.5–59.5 MiB, excluding children and the VM. This quantifies a short isolated-lab workload; continuous high-load operation, lifetime retention and production interference remain unestablished.

B. Hybrid Identity Evaluation

The experiments cover on-premises ADCS and KDC records. Extending the evidence contract to Microsoft Entra ID would require additional identity-mapping and audit-source assumptions. Cross-tenant tokens and synchronization-account compromise are outside the evaluated workload. They should be treated as separate validation tasks before making claims about hybrid identity protection.

C. Threats to Validity and Limitations

We distinguish the following threats to validity and experimental limitations:

1) **Evidence Scale and Label Validity:** The archive's scenario names do not establish seven successful attacks. Four final fixed-request matrices supply 42 successful exact-certificate authentications and six certificate-bound rejections, with nine privileged uses and matched self-use controls. A prospective new-forest cohort adds 24 distinct certificates, including four further privileged uses: the combined primary studies contain 72 certificate cases, 66 successful uses and six rejections. The transfer cohort has new identity namespaces and concurrent multi-template activity but shares the Windows image family. They establish controlled outcomes, not enterprise prevalence. Independent Windows 2019 builds 17763.4974 and 17763.9376 are measured. Current-patch controls reveal request-form differences, but the additional post-rollback workflow prevents attributing every old/new difference solely to the update. Eighteen missing contemporaneous CA exports are explicitly supplemented by a later read-only snapshot; original captures remain intact. Original source images remain read-only.
2) **Static Model and Generator Validity:** The matched audit corrects reachable-path labels and checks 6,000 checkpoint predictions. Repeated training/validation archetypes, fixed first-step transforms, hand-initialized projections, and the distinction between feature-channel and bilinear gating restrict what its numbers establish. A separate literal bilinear study removes those implementation and repeated-whole-input problems with trainable encoders and typed family-disjoint splits. Both literal bilinear and additive attention still miss all 450 long-path positives per arm, without a classification advantage for gating. A verifier restricted to neural positives cannot repair these misses, and symbolic label agreement is not independent Windows ground truth.
3) **Parametric Disruption Costs vs. Interactive Administrator Feedback:** In our Stackelberg remediation game, operational disruption costs $c(e)$ are assigned parametrically according to relation type ($c(\text{MemberOf}) \in [2.8, 3.8], c(\text{GenericAll}) \in [2.0, 3.0], c(\text{Enroll}) \in [1.0, 1.4]$) and operational edge immutability constraints ($E_b \subseteq E$). In production enterprise deployments, operational criticality is context-sensitive and evolving. The exact small-instance audit gives concrete optimum comparisons rather than a universal heuristic guarantee. A metadata-preserving rerun also checks all 120 original graph/budget instances; it changes nine objective outcomes and 24 cut counts. The primary table and revoked-edge comparison now use that corrected implementation. Administrator preference elicitation requires a separate evaluation; the cited graph-hardening study [19] is not evidence that such elicitation was performed here.
4) **Trust, Time, and Necessary Causation:** Candidate retention under a bridge fault budget assumes correct raw issuance/KDC records and captured true issuance. Consistently forged raw histories defeat the methods, while faults exceeding the declared budget invalidate its retention guarantee. A counterexample shows that self-consistent false order can also produce a wrong definite overlap. A grouped-source reference handles the six-record correlated-export control under an explicit one-source assumption, which differs from a record budget. The operation-order pilot uses the controlled orchestrator as an additional trusted source and does not repair the failed Windows audit-clock model. Temporal overlap alone does not establish necessity. The new matched CSR/key interventions support a conditional contrast under the recorded policy fields and controlled CA refresh, while unobserved concurrent changes and missing restoration audit events remain distinct evidence concerns.

IX. Conclusion

CertGraph links certificate issuance and use under an explicit issuer-scoped evidence contract. Its live evaluation verifies 66 successful certificate authentications and six certificate-bound rejections, including 13 administrative uses. The current-patch controls show why a restored template scan and a certificate-use investigation answer different questions. The identity contract can also be implemented using guarded SQL; the evaluated contribution concerns its security requirements and evidence handling rather than a unique reasoning primitive.

The graph-learning results do not establish a classification advantage for bilinear gating. Both matched literal models miss the tested long-path positives, so a verifier that examines only neural-positive cases remains incomplete for this workload. The remediation experiments also show heuristic optimality gaps and budget-dependent differences from greedy

selection. Larger deployments require separate measurements of collection cost, retained history and administrator-assigned disruption costs. The present results support these specific conclusions within the recorded laboratory and generator conditions.

CRediT Authorship Contribution Statement

Md. Hasan Shahriar: Conceptualization, Methodology, Software, Formal Analysis, Investigation, Writing – Original Draft, Visualization, Project Administration. **Taufiq Biswas**: Validation, Data Curation, Formal Analysis, Writing – Review & Editing. **Md. Ramim Hossain**: Validation, Resources, Investigation, Writing – Review & Editing.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data Availability

The versioned CertGraph research artifact contains frozen synthetic protocols, labels, predictions, source snapshots, checkpoints, and offline verification code, together with selected public certificate, CA and KDC evidence for the 72 primary laboratory cases. It is archived at https://doi.org/10.5281/zenodo.24212038. The public-evidence verifier checks 66 successful uses, including 13 administrative uses, and six certificate-bound rejections without private keys or access to the original capture trees. Eighteen CA exports are explicitly identified as later read-only supplements. Private keys, passwords, reusable tickets, VM disks and complete command transcripts are excluded. The release README and hash manifests define the included fields and reproduction boundaries.

Funding

This research received no specific grant from any funding agency.

Ethics and Dual-Use Considerations

The evaluated certificate requests, template changes and authentication attempts were performed in isolated researcher-controlled Windows forests with laboratory accounts. Original images were retained read-only, and execution used writable overlays. The reported experiments concern defensive validation and do not involve production organizations or unsuspecting users. Credentials, private keys and reusable authentication tokens are excluded from public release.

References

[1] L. Zhu and B. Tung, "Public key cryptography for initial authentication in kerberos (PKINIT)," IETF, RFC 4556, June 2006. [Online]. Available: https://www.rfc-editor.org/rfc/rfc4556

[2] W. Schroeder and L. Christensen, "Certified pre-owned: Abusing active directory certificate services," SpecterOps Technical Whitepaper, Tech. Rep., 2021. [Online]. Available: https://posts.specterops.io/certified-pre-owned-d95910965cd2

[3] Microsoft, "KB5014754: Certificate-based authentication changes on windows domain controllers," Microsoft Support, 2025, accessed 2026-11-10. Compatibility and enforcement depend on installed updates. [Online]. Available: https://support.microsoft.com/en-us/servicing/os/windows-server/2022/05/kb5014754-certificate-based-authentication-changes-on-windows-domain-controllers

[4] O. Lyak, "Certipy: Active Directory Certificate Services enumeration and abuse tool," Software, version 5.0.4, 2025, Accessed: Nov. 13, 2026. [Online]. Available: https://github.com/ly4k/Certipy/releases/tag/5.0.4

[5] Q. Liu, K. Bao, W. U. Hassan, and V. Hagenmeyer, "HADES: Detecting and investigating Active Directory attacks via whole network provenance analytics," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 1, pp. 936–953, 2026, doi: 10.1109/TDSC.2025.3611866.

[6] Q. Liu, M. Shoaib, M. U. Rehman, K. Bao, V. Hagenmeyer, and W. U. Hassan, "Accurate and scalable detection and investigation of cyber persistence threats," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 4, pp. 8967–8984, 2026, doi: 10.1109/TDSC.2026.3689905.

[7] R. Geirhos, J.-H. Jacobsen, C. Michaelis, R. Zemel, W. Brendel, M. Bethge, and F. A. Wichmann, "Shortcut learning in deep neural networks," *Nature Machine Intelligence*, vol. 2, no. 11, pp. 665–673, 2020, doi: 10.1038/s42256-020-00257-z.

[8] In.security, "Detecting AD CS SubjectAltName (SAN) abuse using KQL," 2023, accessed November 10, 2026. [Online]. Available: https://in.security/2023/03/02/detecting-ad-cs-subjectaltname-san-abuse-using-kql/

[9] S. Dick, "Windows steal authentication certificates—ESC1 authentication," Splunk Security Content, analytic f0306acf-a6ab-437a-bbc6-8628f8d5c97e, version 10, 2026, created July 28, 2023; updated May 13, 2026; accessed November 10, 2026. [Online]. Available: https://research.splunk.com/endpoint/f0306acf-a6ab-437a-bbc6-8628f8d5c97e/

[10] F. Scarselli, M. Gori, A. C. Tsoi, M. Hagenbuchner, and G. Monfardini, "The graph neural network model," *IEEE Transactions on Neural Networks*, vol. 20, no. 1, pp. 61–80, 2009, doi: 10.1109/TNN.2008.2005605.

[11] Z. Wu, S. Pan, F. Chen, G. Long, C. Zhang, and P. S. Yu, "A comprehensive survey on graph neural networks," *IEEE Transactions on Neural Networks and Learning Systems*, vol. 32, no. 1, pp. 4–24, 2021, doi: 10.1109/TNNLS.2020.2978386.

[12] A. d'Avila Garcez and L. C. Lamb, "Neurosymbolic AI: The 3rd wave," *Artificial Intelligence Review*, vol. 56, no. 11, pp. 12 387–12 406, 2023, doi: 10.1007/s10462-023-10448-w.

[13] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and T. Polk, "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile," RFC 5280, 2008. [Online]. Available:

https://rfc-editor.org/rfc/rfc5280.txt

[14] R. Dechter, I. Meiri, and J. Pearl, "Temporal constraint networks," *Artificial Intelligence*, vol. 49, no. 1–3, pp. 61–95, 1991, doi: 10.1016/0004-3702(91)90006-6.

[15] A. Amarilli, M. L. Ba, D. Deutch, and P. Senellart, "Possible and certain answers for queries over order-incomplete data," in *24th International Symposium on Temporal Representation and Reasoning (TIME)*, ser. LIPIcs, vol. 90, 2017, pp. 4:1–4:19, doi: 10.4230/LIPIcs.TIME.2017.4.

[16] A. K. Elmagarmid, P. G. Ipeirotis, and V. S. Verykios, "Duplicate record detection: A survey," *IEEE Transactions on Knowledge and Data Engineering*, vol. 19, no. 1, pp. 1–16, 2007, doi: 10.1109/TKDE.2007.250581.

[17] R. Heinzl and M. Nissl, "SoK: Timestamps are not a time model: Rethinking temporal reasoning in host-based intrusion detection," arXiv preprint arXiv:2610.35151, 2026, preprint, submitted October 26, 2026.

[18] N. Garg, V. V. Vazirani, and M. Yannakakis, "Multiway cuts in directed and node weighted graphs," in *International Colloquium on Automata, Languages, and Programming (ICALP)*, ser. Lecture Notes in Computer Science, vol. 820. Springer, 1994, pp. 487–498, doi: 10.1007/3-540-58201-0_92.

[19] D. Goel, M. Ward, A. Neumann, F. Neumann, H. Nguyen, and M. Guo, "Hardening active directory graphs via evolutionary diversity optimization-based policies," *ACM Transactions on Evolutionary Learning and Optimization*, vol. 5, no. 3, pp. 1–36, 2025, doi: 10.1145/3688401.

[20] SigmaHQ, "Sigma rule repository: Windows certificate template and certificate authentication rules," 2026, executed with pySigma 2.1.0 and SQLite backend 2.1.1; upstream commit d7c9da10c170a6988d68ebdf2c9f7bd8782b7c55, accessed November 10, 2026. [Online]. Available: https://github.com/SigmaHQ/sigma

[21] Microsoft, "October 13, 2026—KB5126651 (OS build 17763.9376)," Microsoft Support, 2026, october 2026 security build 17763.9376; applicable Server 2019 update verified in the laboratory. [Online]. Available: https://support.microsoft.com/en-us/servicing/os/windows-10/2026/10/kb5126651-windows-10-1809-security-update

[22] ——, "MS-PKCA, section 3.1.5.2.1.6: SID," Microsoft Open Specifications, 2025, updated June 3, 2025; accessed November 10, 2026. [Online]. Available: https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-pkca/e8fd2c1d-50d3-493a-9b58-5e453850c567

[23] S. Holm, "A simple sequentially rejective multiple test procedure," *Scandinavian Journal of Statistics*, vol. 6, no. 2, pp. 65–70, 1979. [Online]. Available: https://www.jstor.org/stable/4615733

[24] J. Zhou, G. Cui, S. Hu, Z. Zhang, C. Yang, Z. Liu, L. Wang, C. Li, and M. Sun, "Graph neural networks: A review of methods and applications," *AI Open*, vol. 1, pp. 57–81, 2020, doi: 10.1016/j.aiopen.2021.01.001.

[25] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, "Graph attention networks," in *International Conference on Learning Representations (ICLR)*, 2018.

[26] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," *ACM Transactions on Privacy and Security*, vol. 26, no. 3, pp. 32:1–32:36, 2023, doi: 10.1145/3588401.

[27] T. Wu, C. Cui, X. Xian, S. Qiao, C. Wang, L. Yuan, and S. Yu, "Understanding the robustness of graph neural networks against adversarial attacks," *Knowledge-Based Systems*, vol. 313, p. 113714, 2025, doi: 10.1016/j.knosys.2025.113714.

[28] M. Zipperle, F. Gottwalt, E. Chang, and T. Dillon, "Provenance-based intrusion detection systems: A survey," *ACM Computing Surveys*, vol. 55, no. 7, pp. 1–36, 2023, doi: 10.1145/3539605.

[29] B. Pan, N. Stakhanova, and S. Ray, "Data provenance in security and privacy," *ACM Computing Surveys*, vol. 55, no. 14s, pp. 1–35, 2023, doi: 10.1145/3593294.

[30] J. Zeng, S. Wu, Y. Chen, R. Zeng, and C. Wu, "Survey of attack graph analysis methods from the perspective of data and knowledge processing," *Security and Communication Networks*, vol. 2019, pp. 1–16, 2019, doi: 10.1155/2019/2031063.

[31] M. Tambe, *Security and Game Theory: Algorithms, Deployed Systems, Lessons Learned*. Cambridge University Press, 2011.

[32] E. Dahlhaus, D. S. Johnson, C. H. Papadimitriou, P. D. Seymour, and M. Yannakakis, "The complexity of multiterminal cuts," *SIAM Journal on Computing*, vol. 23, no. 4, pp. 864–894, 1994, doi: 10.1137/S0097539792225297.